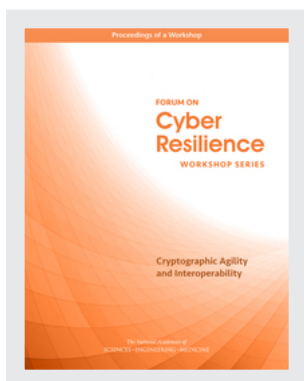


This PDF is available at <https://nap.nationalacademies.org/24636>



Cryptographic Agility and Interoperability: Proceedings of a Workshop (2017)

DETAILS

90 pages | 8.5 x 11 | PAPERBACK

ISBN 978-0-309-45353-0 | DOI 10.17226/24636

CONTRIBUTORS

Anne Frances Johnson and Lynette I. Millett, Rapporteurs; Cyber Resilience Workshop Series Committee; Forum on Cyber Resilience; National Academies of Sciences, Engineering, and Medicine

SUGGESTED CITATION

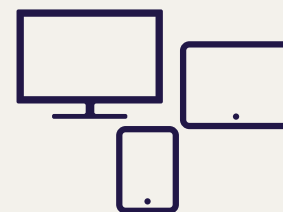
National Academies of Sciences, Engineering, and Medicine. 2017. *Cryptographic Agility and Interoperability: Proceedings of a Workshop*. Washington, DC: The National Academies Press. <https://doi.org/10.17226/24636>.

BUY THIS BOOK

FIND RELATED TITLES

Visit the National Academies Press at nap.edu and login or register to get:

- Access to free PDF downloads of thousands of publications
- 10% off the price of print publications
- Email or social media notifications of new titles related to your interests
- Special offers and discounts



All downloadable National Academies titles are free to be used for personal and/or non-commercial academic use. Users may also freely post links to our titles on this website; non-commercial academic users are encouraged to link to the version on this website rather than distribute a downloaded PDF to ensure that all users are accessing the latest authoritative version of the work. All other uses require written permission. ([Request Permission](#))

This PDF is protected by copyright and owned by the National Academy of Sciences; unless otherwise indicated, the National Academy of Sciences retains copyright to all materials in this PDF with all rights reserved.

FORUM ON
**Cyber
Resilience**
WORKSHOP SERIES

**Cryptographic Agility
and Interoperability**

Proceedings of a Workshop

Anne Frances Johnson and Lynette I. Millett, *Rapporteurs*

The National Academies of
SCIENCES • ENGINEERING • MEDICINE

THE NATIONAL ACADEMIES PRESS
Washington, D.C.
www.nap.edu

The National Academies of SCIENCES • ENGINEERING • MEDICINE

The **National Academy of Sciences** was established in 1863 by an Act of Congress, signed by President Lincoln, as a private, nongovernmental institution to advise the nation on issues related to science and technology. Members are elected by their peers for outstanding contributions to research. Dr. Marcia McNutt is president.

The **National Academy of Engineering** was established in 1964 under the charter of the National Academy of Sciences to bring the practices of engineering to advising the nation. Members are elected by their peers for extraordinary contributions to engineering. Dr. C. D. Mote, Jr., is president.

The **National Academy of Medicine** (formerly the Institute of Medicine) was established in 1970 under the charter of the National Academy of Sciences to advise the nation on medical and health issues. Members are elected by their peers for distinguished contributions to medicine and health. Dr. Victor J. Dzau is president.

The three Academies work together as the **National Academies of Sciences, Engineering, and Medicine** to provide independent, objective analysis and advice to the nation and conduct other activities to solve complex problems and inform public policy decisions. The National Academies also encourage education and research, recognize outstanding contributions to knowledge, and increase public understanding in matters of science, engineering, and medicine.

Learn more about the National Academies of Sciences, Engineering, and Medicine at www.national-academies.org.

CYBER RESILIENCE WORKSHOP SERIES COMMITTEE

FRED B. SCHNEIDER, NAE,¹ Cornell University, *Chair*
ANITA ALLEN, NAM,² University of Pennsylvania
ERIC GROSSE, Google, Inc.
BUTLER W. LAMPSON, NAS³/NAE, Microsoft Corporation
SUSAN LANDAU, Worcester Polytechnic Institute

Staff

LYNETTE I. MILLETT, Director, Forum on Cyber Resilience
EMILY GRUMBLING, Program Officer
SHENAE BRADLEY, Administrative Assistant

FORUM ON CYBER RESILIENCE

FRED B. SCHNEIDER, NAE, Cornell University, *Chair*
ANITA ALLEN, NAM, University of Pennsylvania
BOB BLAKLEY, CitiGroup, Inc.
FRED H. CATE, Indiana University
DAVID D. CLARK, NAE, Massachusetts Institute of Technology
RICHARD J. DANZIG, Center for a New American Security
ERIC GROSSE, Google, Inc.
DAVID A. HOFFMAN, Intel Corporation
PAUL C. KOCHER, NAE, Cryptography Research Division, Rambus, Inc.
TADAYOSHI KOHNO, University of Washington
BUTLER W. LAMPSON, NAS/NAE, Microsoft Corporation
SUSAN LANDAU, Worcester Polytechnic Institute
STEVEN B. LIPNER, Independent Consultant
DEIRDRE K. MULLIGAN, University of California, Berkeley
TONY W. SAGER, Center for Internet Security
WILLIAM H. SANDERS, University of Illinois, Urbana-Champaign
STEFAN SAVAGE, University of California, San Diego
PETER SWIRE, Georgia Institute of Technology
DAVID C. VLADECK, Georgetown University
MARY ELLEN ZURKO, Cisco Systems, Inc.

Ex Officio

DONNA F. DODSON, National Institute for Standards and Technology
JAMES KUROSE, National Science Foundation
WILLIAM B. MARTIN, National Security Agency

Staff

LYNETTE I. MILLETT, Director
EMILY GRUMBLING, Program Officer
KATIRIA ORTIZ, Research Associate
SHENAE BRADLEY, Administrative Assistant

For more information about the forum, see its website at <http://www.cyber-forum.org>,
or e-mail the forum at cyberforum@nas.edu.

¹National Academy of Engineering.

²National Academy of Medicine.

³National Academy of Sciences.

COMPUTER SCIENCE AND TELECOMMUNICATIONS BOARD

FARNAM JAHANIAN, Carnegie Mellon University, *Chair*
LUIZ ANDRE BARROSO, Google, Inc.
STEVEN M. BELLOVIN, NAE, Columbia University
ROBERT F. BRAMMER, Brammer Technology, LLC
EDWARD FRANK, Cloud Parity, Inc.
LAURA HAAS, NAE, IBM Corporation
MARK HOROWITZ, NAE, Stanford University
ERIC HORVITZ, NAE, Microsoft Research
VIJAY KUMAR, NAE, University of Pennsylvania
BETH MYNATT, Georgia Institute of Technology
CRAIG PARTRIDGE, Raytheon BBN Technologies
DANIELA RUS, NAE, Massachusetts Institute of Technology
FRED B. SCHNEIDER, NAE, Cornell University
MARGO SELTZER, Harvard University
JOHN STANKOVIC, University of Virginia
MOSHE VARDI, NAS/NAE, Rice University
KATHERINE YELICK, University of California, Berkeley

Staff

JON EISENBERG, Director
LYNETTE I. MILLETT, Associate Director

VIRGINIA BACON TALATI, Program Officer
SHENAE BRADLEY, Administrative Assistant
JANEL DEAR, Senior Program Assistant
EMILY GRUMBLING, Program Officer
RENEE HAWKINS, Financial and Administrative Manager
KATIRIA ORTIZ, Research Associate

For more information on CSTB, see its website at <http://www.cstb.org>, write to CSTB, National Academies of Sciences, Engineering, and Medicine, 500 Fifth Street, NW, Washington, DC 20001, call (202) 334-2605, or e-mail the CSTB at cstb@nas.edu.

Preface

The Forum on Cyber Resilience—a roundtable established in 2015 by the National Academies of Sciences, Engineering, and Medicine—facilitates and enhances the exchange of ideas among scientists, practitioners, and policy makers who are concerned with urgent and important issues related to the resilience of the nation’s computing and communications systems, including the Internet, other critical infrastructures, and commercial systems. Forum activities help to inform and engage a broad range of stakeholders around technology and policy issues related to cyber resilience, cybersecurity, privacy, and associated emerging issues. A key role for the forum is to uncover and explore topics that can help advance the national conversation.

During our early discussions exploring technical aspects of cyber resilience, the question of how to deploy systems whose cryptographic elements would be resistant to eventual quantum computers arose. Further discussion made clear that because we are all highly dependent on widely deployed cryptosystems, there is a complex, rich set of issues, beyond the potential impact of quantum computers, that affects how resilient our information and communications systems are (or could be) with regard to the cryptographic components used to ensure data secrecy, integrity, and authenticity. Cryptographic agility encompasses not just what can be done about the prospects of quantum computing breaking widely deployed public-key cryptography, but also how to address newly-discovered flaws in long-deployed cryptographic components such as Secure Sockets Layer/

Transport Layer Security (SSL/TLS)¹ (the technology that secures links between web servers and browsers), as well as challenges related to nation-state preferences for homegrown cryptographic suites in commodity operating systems. Cryptographic agility thus not only poses difficult technical challenges, but also has economic and foreign policy implications.

To explore these issues further, the forum decided to host a workshop. A planning group has been appointed to oversee the forum's workshop series. This workshop, held on May 9, 2016, in Washington, D.C., featured invited speakers from government, the private sector, and academia. This workshop proceedings summarizes the presentations made by invited speakers and remarks made by workshop participants, as well as the ensuing discussions. In keeping with the workshop's exploratory purpose and the National Academies' guidelines, this proceedings does not contain findings or recommendations, nor does it necessarily reflect consensus views of the workshop participants or planning committee. The planning committee's role was limited to organizing the workshop, and the workshop proceedings has been prepared by the workshop rapporteurs and forum staff as a factual summary of what occurred at the workshop.

The introduction provides an overview of the workshop and reproduces background material provided to all participants. Chapters 1 through 5 summarize speaker presentations. Note that although the chapter headings reflect the titles given to these sessions at the workshop, most speakers covered many aspects of the topic. Chapter 6 describes the content of the final plenary discussion, highlighting some of the broader themes that emerged throughout the workshop. The workshop agenda and participants list are provided in Appendix A. Short biosketches of the planning committee and speakers appear in Appendixes B and C, respectively.

We hope that the workshop and this proceedings will encourage the exchange of ideas and fresh thinking about the critical cryptographic technologies that underpin much of our economy and critical infrastructure.

My sincere thanks to the planning committee, forum members, and staff who planned and organized the workshop as well as the invited speakers for their thoughtful remarks and enthusiastic participation in the discussions that ensued. Writing support was provided by Anne Frances Johnson and Kathleen Pierce, Creative Science Writing. We also extend our appreciation to the National Science Foundation, the National Security Agency, the Special Cyber Operations Research and Engineering Working Group, and the National Institute of Standards and Technology for their support and encouragement of forum activities.

Fred B. Schneider, *Chair*
Forum on Cyber Resilience

¹SSL and TLS are two names for the same family of security protocols. SSLv2 and SSLv3 were developed by Netscape and the name of the protocol was changed to TLSv1 when it was standardized by (and change control moved to) the Internet Engineering Task Force.

Contents

WORKSHOP INTRODUCTION 1

Opening Remarks 1

Workshop Context and Charge 4

1 CONTEXT 7

Cryptography: If and When It Breaks 7

Lessons Learned from Real-World Cryptography 11

2 GOVERNMENT AND INFRASTRUCTURE 19

How the National Institute of Standards and Technology Thinks
About Cryptography 19

Cryptography Through the Years 24

3 STANDARDS AND SECURITY IMPLICATIONS 29

RFC 7696: Guidelines for Cryptographic Algorithm Agility and
Selecting Mandatory-to-Implement Algorithms 29

Cryptographic Agility in the Real World 34

4 ENGINEERING AT SCALE AND USER IMPLICATIONS 39

Transport Layer Security and the Downsides of Agility 39

Extensibility and Agility 44

The Importance of the Human Factor in Cryptographic Agility 49

5 RESEARCH, INDUSTRY, AND POLICY IMPLICATIONS 53

Agility Is Essential (But Extremely Challenging) 53

Agility and the Need to Prepare for Failure 57

6 DISCUSSION AND WRAP-UP 62

Planning for an Uncertain Future 62

Technical Solutions 63

Sharing Expertise 64

International Issues and Human Rights 65

Agility Beyond Cryptography 66

APPENDIXES 67

A Workshop Agenda and Participants List 68

B Planning Committee Biographies 71

C Speaker Biographies 74

ACKNOWLEDGMENT OF REVIEWERS

This workshop proceedings has been reviewed in draft form by individuals chosen for their diverse perspectives and technical expertise. The purpose of this independent review is to provide candid and critical comments that will assist the institution in making its published proceedings as sound as possible and to ensure it meets institutional standards for objectivity, evidence, and responsiveness to the project's charge. The review comments and draft manuscript remain confidential to protect the integrity of the deliberative process. We wish to thank the following individuals for their review of this proceedings:

Paul Kocher, Cryptography Research Division, Rambus, Inc., NAE,¹
Brian LaMacchia, Microsoft Corporation,
John Manferdelli, Google, Inc., and
JR Rao, IBM Corporation.

Although the reviewers listed above have provided many constructive comments and suggestions, they were not asked to endorse the views presented at the workshop, nor did they see the final draft of the proceedings before its release. The review of this report was overseen by Samuel H. Fuller, Analog Devices, Inc., NAE, who was responsible for making certain that an independent examination of this proceedings was carried out in accordance with institutional procedures and that all review comments were carefully considered. Responsibility for the final content of this proceedings rests entirely with the authors and the institution.

¹National Academy of Engineering.

Workshop Introduction

The Forum on Cyber Resilience of the National Academies of Sciences, Engineering, and Medicine hosted a Workshop on Cryptographic Agility and Interoperability at its Spring 2016 meeting, on May 9, 2016, in Washington, D.C.

The workshop featured 11 speakers who addressed various aspects of cryptographic agility and interoperability. These distinguished researchers, computer scientists, and industry leaders shared their diverse experiences and expertise related to the history and practice of cryptography, its current challenges, and its future possibilities. They also asked questions, probed assumptions, and explored uncertainties when dealing with cryptography.

The meeting was open to the public. This proceedings was created from the presenters' slides, the rapporteurs' notes, and a full transcript of the workshop; it is intended to serve as a public record of the workshop presentations and discussions.

OPENING REMARKS

Fred B. Schneider, Samuel B. Eckert Professor of Computer Science at Cornell University, member of the National Academy of Engineering, and workshop chair, opened the meeting with a brief description of the National Academies' Forum on Cyber Resilience. The forum convenes experts from various backgrounds to examine the complicated issues

surrounding cybersecurity and, more broadly, cyber resilience. The forum offers experts in technology, policy, and research an opportunity to discuss critical emerging issues or raise topics that are insufficiently addressed or perceived to be underappreciated. Although the forum does not conduct traditional National Academies' studies, Schneider noted that forum members and the ideas discussed at workshops hosted by the forum can lead to the creation of such studies when deemed appropriate.

Schneider noted that this workshop focused on challenges surrounding cryptographic agility and interoperability. Cryptography is the creation of codes or algorithms to secure communications. Cryptographic agility refers to how easy it is to evolve or replace the hardware, software, or entire information technology (IT) systems being used to implement cryptographic algorithms or protocols (and, in particular, whether the resulting systems remain "interoperable"). Although cryptographers and computer systems designers might be confident in their work and may not see a strong need for cryptographic agility, "the reality is that we now know that cryptography breaks," Schneider said.

For example, Schneider cited concerns about the possibility of quantum computers—technologies in very early research stages that would employ a fundamentally different approach from today's computers. If quantum computing becomes a reality, today's public-key cryptography systems—which are the basis for securing electronic communications in open environments such as the Internet—would be vulnerable to compromise. Agility would make defense against the emergence of quantum computers easier because it would allow simple substitution of quantum-resistant public-key algorithms for today's widely deployed (and quantum-susceptible) algorithms.

Schneider also drew attention to some immediately practical issues, beyond developing defenses against hypothetical quantum computers, that improvements in cryptographic agility could help address. For example, what happens when foreign nations or other entities want to add their own cryptographic suites to commodity software, instead of using cryptographic approaches provided by the manufacturer? Support for this kind of change requires cryptographic agility in the deployed systems. The prospect of deploying more agile cryptography systems also raises some hard questions about trust: Who should be authorized to change cryptography in a deployed system? Schneider noted that changing cryptography systems can typically cause "really annoying little headaches," such as the need to change key size or format, and the difficulty and expense of replacing cryptographic code that pervades several layers of software. Such headaches are actually symptoms of a broader set of issues that encompasses not only engineering and design problems but also questions of trust, policy, and even foreign relations, Schneider said.

Despite this broad set of issues, Schneider noted that there has not yet been much discussion of this topic outside of highly technical communities. The intent of this workshop is to help explore the issues, educate a wider community, and identify where further work is needed.

Workshop Context and Charge

The following information was provided to workshop speakers and attendees to offer context on cryptographic agility and interoperability and to provide a structure for the workshop and its intended purposes.

Background

This workshop is an activity of the National Academies' Forum on Cyber Resilience. The Forum on Cyber Resilience facilitates and enhances the exchange of ideas among scientists, practitioners, and policy makers who are concerned with urgent and important issues related to the resilience of the nation's computing and communications systems, including the Internet, other critical infrastructures, and commercial systems. Forum activities help to inform and engage a broad range of stakeholders around issues related to technology and policy in the context of cyber resilience, cybersecurity, privacy, and related emerging issues. A key role for the forum is to surface and explore topics that can help advance the national conversation. This workshop focuses on the topic of cryptographic agility and interoperability. Additional context and questions to consider for discussion are below.

Context

We rely on established cryptographic algorithms, protocols, and implementations to secure our data and communications. Greater agility with respect to cryptosystems could potentially help stakeholders better adjust to rapidly changing cybersecurity and privacy landscapes. For example, security leaders might desire the ability to quickly substitute one algorithm, protocol, or implementation for another following the discovery of significant weakness. Individual users may desire the ability to customize the security and speed of their communications, depending on the nature of their use. Governments may wish to set their own standards, especially if they do not trust those developed by other entities. Achieving such agility, however, poses both technical and policy challenges.

Generally although cryptographic algorithms and protocols are being deployed in an ever wider array of systems, our understanding of how to achieve agility, when to prioritize it, and how best to deploy it is limited. Today, some widely used systems have elements of cryptographic agility. For example, the widespread practice of software updates has been a way to achieve a measure of agility by allowing changes to be made through the deployment of security patches. Some protocols, including SSL/TLS and SSH, allow implementations to negotiate algorithm combinations. However, the authenticity and integrity of the software update mechanisms or negotiation processes are themselves ensured with cryptography—which may or may not be agile. Today, our understanding of how cryptosystems can improve agility, as well as the associated limitations and risks, remains limited.

There are two main technical problems that have to be solved to achieve agility in practice. The first is *deployment*: how to securely deploy new code to all the places where it needs to run. The second is *selection*: how to choose the cryptographic suite to use; it must be one that all the parties to the communication can handle, and it must meet the requirements of all the applications and legal jurisdictions involved.

Deployment itself needs cryptography to authenticate that the new code that is received and installed is what was intended. How can we make this cryptography itself agile? In addition, code that implements cryptographic algorithms and protocols runs in many different kinds of endpoints, in some cases in special purpose hardware such as network interface controllers and trusted platform modules. How can we create code that can run in all these endpoints, and how can we ensure that it gets deployed to all of them?

An endpoint can usually run several different cryptographic suites so that it can talk to a variety of other endpoints (including old ones), meet legal or contractual requirements, or make trade-offs between security and performance. Today the application and the operating system together specify a set of acceptable suites for each endpoint, and the endpoints together try to select the “best” suite that is acceptable to all of them. Both of these processes are complicated and poorly specified, and have given rise to many bugs. How can we design a selection mechanism that meets these needs, is understandable, and is implemented correctly? What mechanisms can we put in place to protect against defaulting to the weakest algorithm in the set?

Challenges related to cryptographic agility cover the following areas:

- Cryptographic algorithms—algorithm-specific cryptanalytic advances or fundamentally new techniques (such as quantum computing) may necessitate algorithm replacements;
- Cryptographic protocols—updates to how cryptographic protocols negotiate and use cryptographic methods and other agreements may be needed to address security issues or to add/remove functionality;
- Endpoints—cryptographic implementations in endpoint devices and systems range from more agile approaches (such as updatable software) to more robust but less agile approaches (such as implementations in hardware);
- Key management—changes to how keys and credentials are generated, exchanged, stored, replaced, and revoked may be desired;
- Trusted parties—some agility mechanisms rely on trusted third parties, such as product developers or certification authorities, to produce and distribute updates; and
- Users—some agility mechanisms depend on user involvement, for example to make configuration decisions, resolve security alerts, or consent to updates, while some devices (such as “Internet of Things” devices) lack any user interface.

Separate from the technical challenges are questions of prioritization and economic trade-offs. When is it appropriate to design for agility and when might an emphasis on designing for truly long-term security be appropriate? For instance, for some critical applications it may be preferable to deploy cryptography that can persist and be secure for a century and those who need such security would have to be willing to tolerate significantly reduced performance to do so. Moreover, although on the surface decisions related to cryptographic agility appear technical, there are economic trade-offs in the decision to support multiple standards. It is not obvious that these trade-offs have been well understood or assessed in the past.

The workshop was designed to feature presentations on the drivers and technical and societal implications of increased cryptographic agility, addressing the following:

- Motivations for and benefits of increased agility (security, technical, social, political),
- Challenges to implementation (technical, social, political), and
- Impacts (security, technical, social, political).

Discussion Questions for Speakers and Participants to Consider

Why is cryptographic agility useful and what are its potential risks and impacts?

What approaches have been attempted for improving cryptographic agility, and how successful have they been? For example, how easy is it today to replace defeated or outdated cryptographic tools in widely deployed commercial software and systems?

How should the trade-off be made between supporting multiple algorithms (thus enabling agility in case of future problems) and supporting fewer algorithms? How does that trade-off differ by domain? What economic, social, and policy factors enter into that decision?

What are the consequences of supporting cryptographic agility on legacy data and systems? What are the trade-offs related to continuity (e.g., allowing continued use of existing encrypted, signed, or hashed data) and compatibility (such as systems having varying configuration settings and update status) when cryptographic regimes are deprecated?

How might more control over (and more variation in) cryptographic routines affect trust in systems by individuals, companies, and governments? For example, are there ways to address concerns that updates may (accidentally or intentionally) create new security vulnerabilities?

Does the complexity of agility mechanisms themselves or the security modes they enable create security risks?

How might privacy and human rights be affected by cryptographic agility?

What likely market or economic drivers affect how and whether companies support and improve cryptographic agility in their products? What might happen if support is not maintained for deprecated routines given longer-lasting embedded systems, such as found in Internet of Things devices?

What are likely geopolitical drivers of more crypto-agile systems, and what might be the impacts on the global Internet and international politics?

What are the consequences of cryptographic agility for the interoperability and usability of communications systems?

How and on what basis should efforts to improve cryptographic agility be prioritized?

What are the key opportunities for standards bodies, governments, researchers, systems developers, and other stakeholders with regard to cryptographic agility?

Context

The first two speakers, Bob Blakley and Paul Kocher, addressed contexts for cryptographic agility, including the likelihood that cryptographic systems fail as well as the potential sources, causes, and consequences of such failure. Kocher also described lessons learned from real-world experiences with cryptography.

CRYPTOGRAPHY: IF AND WHEN IT BREAKS

Bob Blakley, CitiGroup, Inc.

Bob Blakley, global head of information security innovation at CitiGroup, Inc., emphasized that cryptographic agility is a significant information security problem that needs to be tackled. Noting that most cryptographic systems have eventually failed in use, he described deployed cryptographic systems as prime examples of technologies that are “almost always ultimately doomed to fail.” He pointed out that only one cryptographic system, the Data Encryption Standard (DES), was considered as strong at the time of its retirement as it was on the day of its release.

Blakley noted that a clever mathematician could, in principle, crack any cryptographic system (with the exception of a one-time pad) and compromise significant portions of the current cryptographic infrastructure. In addition to being vulnerable to

breakthroughs in traditional cryptanalysis, many public-key cryptography systems would also be vulnerable to attack by a quantum computer.

Exploring this issue further, he discussed why vulnerabilities in cryptographic systems are a significant potential challenge. Most of the time, attacks against the underlying cryptographic components of cryptographic systems result in immediate vulnerabilities—mathematical problems that weaken the system and can only be fixed by replacing the entire cryptographic system. Blakley estimated that completely replacing a widely deployed system would take at least 3 years—assuming that there is already a well-tested replacement system ready for deployment. The timeline would expand to 10 years or more, he said, if a new cryptographic approach had to be developed from scratch starting at the time of the discovery of the vulnerability in the old system. As a result, he said, “It is important to look a long way ahead if you begin to suspect that there might be a problem.” Although attacks occur suddenly, the necessary repairs can take years.

Replacing a system completely takes a long time because it requires an enormous amount of work. Blakley described some of the necessary steps: A new cipher would have to be invented, put through a battery of tests, and standardized for wide use. Then it would have to be implemented in a variety of cryptographic libraries; hardware would need to be updated to support it; and *then* it would have to be bought, deployed in actual products, purchased, and put into use. Meanwhile, the old, broken systems would have to be retired so no vulnerabilities would be left behind.

Unfortunately, no one can predict when a cryptographic system will break, but given the years it would take to roll out new cryptographic systems, the need for improved agility is apparent. The federal government has begun thinking about this challenge, in particular the potential need for quantum-resistant cryptography. Blakley noted that the National Security Agency recently issued a document encouraging developers to plan for quantum-safe cryptographic systems.¹ The National Institute of Standards and Technology also recently announced an effort to select and standardize quantum-safe cryptographic algorithms.²

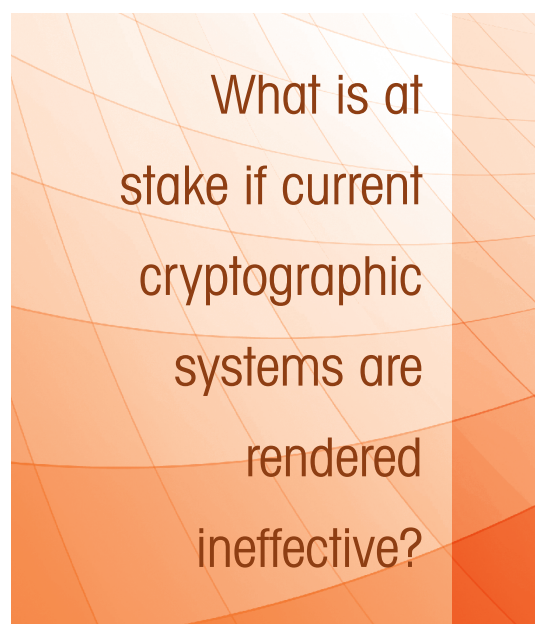
Blakley said experts put the timeline for developing new cryptographic systems, including standardization and deployment, at roughly 10 years. However, the pace is clearly influenced by perceived urgency, which varies depending on how far off one thinks quantum computing is. Blakley pointed out that smaller quantum computers already exist, comprised of on the order of 5 qubits, but he suggested the timing of the

¹Fuzzy, “NSA Switches to Quantum-Resistant Cryptography,” February 8, 2016, <https://apps.nsa.gov/iaarchive/programs/iad-initiatives/cnsa-suite.cfm>.

²National Institute of Standards and Technology, 2016, “NIST Kicks Off Effort to Defend Encrypted Data from Quantum Computer Threat,” April 28, <https://www.nist.gov/news-events/news/2016/04/nist-kicks-effort-defend-encrypted-data-quantum-computer-threat>.

development of a quantum computer capable of breaking something like RSA 2048, an extremely strong encryption system, “is a good deal more uncertain.”

It is also conceivable that a quantum computer containing more than a few qubits will turn out to be too challenging to develop. Blakley pointed to a recently published comparison of optimistic and pessimistic hypotheses in which the author, a mathematician, concludes that quantum computing on a practical scale is unlikely to be possible for physical reasons.³ Industry giants Microsoft, Google, and IBM, on the other hand, are optimistic;



all are working on building a quantum computer, and they predict success within 4 to 10 years. Blakley noted Google’s claim that a company called D-Wave has built a special purpose quantum computer, although it is unclear whether its speed comes from quantum mechanics or just extremely fast digital computing.

As a systems security expert, Blakley said he is less focused on the potential benefits of quantum computing and more concerned about what it could break. It is a common belief that widely deployed public-key cryptographic systems would be “rendered totally useless” in the context of quantum computing, he said. Symmetric-key cryptography (which is based on shared secrets) would also be vulnerable to the incredible speed with which quantum computers could break encryption

codes designed to resist slower traditional computers. Blakley observed that this vulnerability could be mitigated by increasing symmetric-key cryptosystem key lengths by a factor of at least two; key expansion seems to be considered by cryptosystem designers more feasible than it has been in the past.

What is at stake if current cryptographic systems are rendered ineffective? Public-key systems, server authentication infrastructure, personal computer updates, digital signature systems, and, most worrisome to Blakley, our system integrity infrastructure (i.e., code signing) would all be compromised. All of these systems, which play crucial roles in global finance, personal privacy, and national security, depend on the integrity of public-key cryptographic systems.

More concretely, banking and e-commerce protocols are among the software systems that rely heavily on public-key distribution systems and, like other public key–based systems, would be at risk if current cryptographic systems were broken by a quantum computer. Given the level of disruption, and the fact that trillions of dollars are transacted

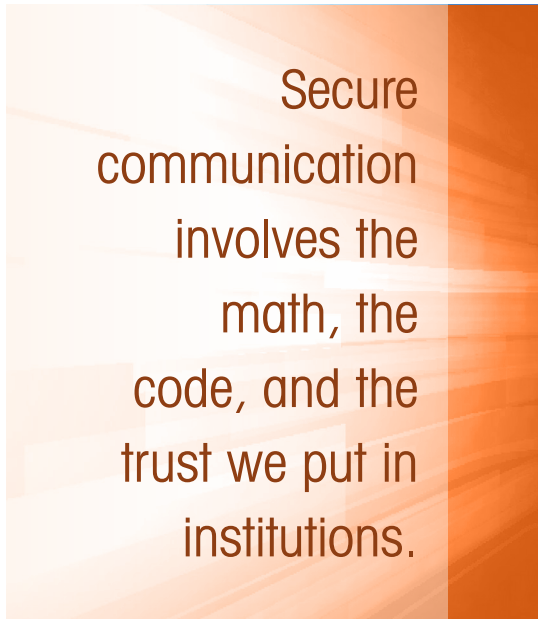
³G. Kalai, 2016, The Quantum Computer Puzzle. American Mathematical Society, *Notices of the American Mathematical Society* 63(05): 508-516.

using banking and e-commerce protocols protected by public-key cryptography, Blakley surmised that “it does not seem farfetched that an economically rational attacker would be willing to spend a billion dollars to build a quantum computer.”

Even if quantum computers turn out to be impossible to build, Blakley asserted that it is plausible to believe that there will be future “mathematical land mines” that could weaken public-key cryptographic systems without any help from a quantum computer.

What is the solution if current cryptographic systems break? Whatever it is, Blakley said, waiting 10 years is too long for comfort. A new cryptographic system should be deployment ready and easy to implement and interoperate with—which, Blakley reiterated, is a monumental task.

Blakley closed by underscoring the risks and consequences of cryptographic failure.



Secure
communication
involves the
math, the
code, and the
trust we put in
institutions.

Noting that in the original Greek, the word “apocalypse” meant “the day that all secrets will be revealed,” he said the end of today’s cryptographic systems would be a literal apocalypse—an “instantaneous, simultaneous global failure” of all information security. He emphasized that it is very difficult to calculate the risk of such an event. Widespread simultaneous cryptographic failure is a “black swan” problem: Because it has never happened, there is no way to calculate when it *might* happen. Blakley also likened it to an asteroid hitting Earth: While it may not be very likely to happen, that does not mean that one should not plan for it. Finally, Blakley summarized the message of the Sherlock Holmes story “The Adventure of the Dancing Men”: “What the mind of one man can invent, another can discover.”

Because people can conceive of quantum computing and other forms of code-breaking, he said, “I think it would pay for us to be worried about the discovery of something that would vitiate all of our public-key infrastructure and to start planning for that.” He concluded by expressing his hope that something to more readily allow changes in cryptography infrastructure as circumstances warrant would be developed by the year 2020.

Peter Swire, Georgia Institute of Technology, opened the discussion by asking Blakley to speculate on the probability of a significant break of widely deployed cryptography. Reiterating his belief that it is impossible to quantify the risk, Blakley said he prefers to plan for the worst-case scenario, which in his view means assuming that a quantum computer will be operational by the end of 2020. Fred Schneider, Cornell University,

commented that whether or not quantum computers become a reality, cryptographic systems will still break, and cryptographic agility will still be required.

Anita Allen, University of Pennsylvania Law School, questioned whether it might be prudent to more precisely define the term “cryptographic systems.” Blakley suggested a need for a deeper discussion of this topic but noted his belief that it would be helpful to expand beyond cryptographic systems as formally defined when thinking about secure communication. Butler Lampson, Microsoft Corporation, pointed to three levels involved in secure communication: the math, the code, and the trust we put in institutions to authenticate our communication, each of which is subject to compromise. These three levels and their differences create confusion in the cryptography discussion, he said.

Lynette Millett, National Academies, noted that although the well-known Y2K bug once seemed like a huge problem requiring significant engineering effort, it was successfully resolved in time to avoid major issues. She asked whether there are lessons for policy makers and engineers that could be drawn from that experience and how the effort required to solve that comparatively simple problem compares to what would be needed for effective cryptographic agility. Blakley noted that companies like IBM began working on the Y2K issue in the early 1980s, suggesting that much time and work were required to fix it.

Paul Kocher, Cryptography Research Division, Rambus, Inc., brought up another ramification of quantum computing or the discovery of another significant weakness: its potential ability to retroactively cause cryptographic breaks and decrypt any encrypted material that has been saved. That is, if data have been encrypted and stored under a particular cryptographic system, and that system is broken, all of those data are now vulnerable to exposure. Some data, such as that pertaining to national security and the identity of spies, require long-term protection. The potential vulnerability of this information, he noted, increases the urgency of making cryptographic systems quantum safe.

LESSONS LEARNED FROM REAL-WORLD CRYPTOGRAPHY

Paul Kocher, Cryptography Research Division, Rambus, Inc.

Paul Kocher is the president and chief scientist at Rambus’ Cryptography Research Division. His presentation focused on the questions, challenges, and lessons learned from his time designing systems for use in the field.

Kocher cautioned, however, that while creating and implementing agility mechanisms brings benefits, it can also open up new risks and cause other complications. He expressed mixed feelings about the trade-offs of developing agile cryptographic systems, noting that his experience has left him “very cynical, but also optimistic.” Beyond the

threat of quantum computing discussed by Blakley, Kocher emphasized that there are many other reasons to want security mechanisms to be agile. In addition to technical aspects, he noted that agility also has legal, moral, and policy implications, and powerful economic forces can influence whether agility mechanisms succeed or fail.

Kocher shared three cryptography case studies from his work to illustrate both positive and negative outcomes: improving the Secure Sockets Layer/Transport Layer Security (SSL/TLS) protocol, combating piracy of pay television, and securing copyrighted material on Blu-ray discs.

The Secure Sockets Layer/Transport Layer Security Protocol

In 1996, Kocher was asked by Netscape to help fix the poorly designed SSLv2 protocol, which direly needed to be upgraded or replaced. The task was enormous and full of uncertainties: What were the technical requirements? How quickly could a replacement be prepared? Could the new solution support the current cryptographic algorithms (known as “backward compatibility”)?

Kocher described how it quickly became clear that there would be no “goldilocks” solution. Each algorithm under consideration worried different parties. Netscape had signed an agreement with the Department of Defense that required the use of FORTEZZA, a cryptographic system specially created for classified information but with a key escrow mechanism that would be unacceptable for commercial use. Triple DES was slow and had problems with its modes of operation. Rivest Cipher 4 (RC4) was currently in widespread use but was not adequately reviewed. The RSA public-key cryptosystem was constrained by patents. In short, there was no single “good and reliable” algorithm to which he could turn.

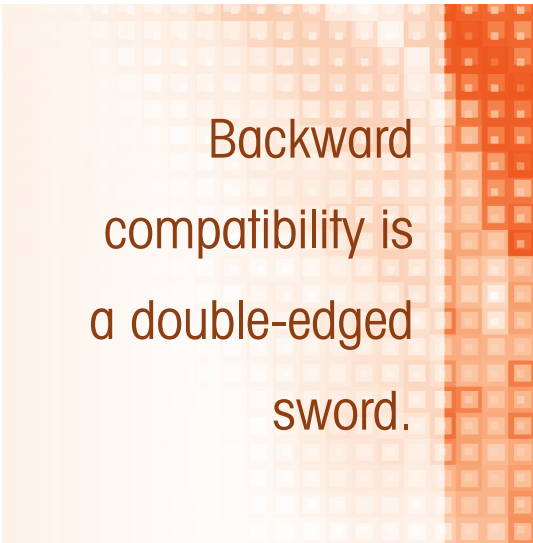
Ultimately, the team was unable to select any single combination of algorithms that functioned as well as it wanted; the problem was just too large for its time. RSA keys were too small to be effective over the long term, and only newer algorithms, which Kocher saw on the horizon but had not been created yet, could build something more reliable and durable.

Kocher also noted that legal export restrictions further compounded the challenge. U.S. export restrictions at that time required that “export” versions of browsers and servers support only short, insecure key sizes. At the same time, customers in areas like banking and e-commerce needed strong security. Complicating matters, non-export servers needed to be able to fall back to weak cryptography when communicating with exportable browsers, and non-export browsers needed to be able to fall back to weak cryptography when communicating with exportable servers—but these mechanisms needed to prevent attackers from tricking non-export browsers into using breakable cryptography with non-export servers.

While cryptographic agility mechanisms needed to be created to address the protocol's needs, Kocher was unable to find any applicable agility research to guide his team. Rather, he discovered that SSLv2 and other existing protocols typically could be tricked into using the security of the worst supported configurations. This was one of the reasons he decided to work on SSLv2's replacement, SSLv3, essentially from scratch.

First, Kocher said, the team decided not to design the protocol to negotiate every setting separately. With all the different combinations and possible interactions among encryption algorithms, modes of operations, authentication algorithms, and key sizes, some were bound to combine negatively. Compatibility problems also had to be addressed, such as cases where some hardware might support only certain key sizes for a particular algorithm.

The SSLv3 cipher suite approach is designed to address compatibility. Each cipher suite specifies a permitted configuration, typically including an encryption algorithm (and its mode of operation), an authentication algorithm (e.g., message authentication code [MAC]), and the associated key size. A cipher suite negotiation mechanism was also de-



Backward
compatibility is
a double-edged
sword.

finied so that a client and server would select the strongest cipher suite they have in common. However, if the only algorithms a client and server have in common are insecure ones (e.g., because one or both allowed only weak exportable cryptography), then the “best” option could be very weak—or have no encryption at all. (SSLv3 defines cipher suites that include integrity checks but no encryption.)

In the actual “handshake” process used in SSLv3, the client sends the server a list of all cipher suites it will accept in the order of the client's preference, and the server chooses one from the client's given list. If the messages exchanged between the client and server are

correct (and unmodified by an attacker), the protocol clearly works as intended. (The SSL/TLS protocol does not attempt to protect against badly behaved clients or servers making bad choices.) An active man-in-the-middle attacker could modify the client's list and/or the server's selection, tricking them into agreeing on a mutually supported option that is weaker than the one they would otherwise choose. To deal with this case, the parties include the negotiation messages in computing MACs, thwarting the attack. With this negotiation approach, Kocher said, “If things are done right, you end up with the strongest combination that they both support, and it works pretty well.” On the other hand, Kocher pointed out that if either the server or the client is not completely

secure, the entire connection will be insecure, regardless of the strength of one side's cryptography.

Despite these advantages of SSLv3, Kocher noted some caveats. The negotiation works for symmetric (non-public-key) algorithms, but if the client or server supports weaker public keys, those can be forced into use by an adversary. Here, the public-key algorithms and key sizes are each a point of failure rather than a strong protector. An insecure connection can also result if the negotiated cipher suite is not sufficiently secure. Unfortunately the ultimate decision about which public-key algorithms (and their key sizes) to support, as well as the list of cipher suites to support (and their rankings), is typically made by an implementer or systems administrator. Experience demonstrates that they often make poor security choices. To correct for this problem, Kocher said, "Implementations need to be correct and secure."

Kocher emphasized the enormous complexities he encountered trying to build from scratch this real-world protocol with many challenging security, interoperability, and performance requirements. The constant push and pull, pain, and messiness of various versions of the protocol led him to believe that in the end, "it may have still been too complex for our brains." In computer security, we have often "vastly overestimated our ability to understand complexity," he said. Although he conceded that the team made some design mistakes, the overall protocol has been successful and the issues have been correctable with relatively modest changes. He also noted that while academics can ignore practicalities, real-world applications cannot. Agility mechanisms introduce complexity, which leads to unknown consequences; Kocher expressed skepticism of any proof of security that fails to take into account the way a product or algorithm is deployed and behaves in the field.

Key Lessons from the Secure Sockets Layer Experience

Kocher outlined some lessons learned through this arduous process. First, the SSL/TLS cipher suites provide a form of agility. New suites can be added or adapted gracefully; for example, cipher suites that offer quantum resistance can be added. Once standard quantum-resistant cryptographic algorithms become available, he believes that defining and adding new cipher suites should be a straightforward process.

Unfortunately, the ability to negotiate cipher suites also has downsides. For example, the choice of which mix to support in the protocol is often made by committees, which can get mired in personal concerns or pet projects. As a result, committees can allow bad choices to "muddle along," leading to bad decisions in the long term.

In Kocher's experience, backward compatibility is also a double-edged sword. In part because SSLv3 included smooth backward compatibility with SSLv2, the SSLv2 protocol was not fully retired as expected. Instead, many implementers left SSLv2 enabled.

Just last year, two research projects demonstrated problems in SSLv2 backward compatibility mechanisms that are still present in current software versions. Kocher described being “just absolutely aghast” that pieces of SSLv2, the protocol he was tasked to completely replace, were still around 20 years later.

Another solution that perhaps worked too well was SSLv3’s near-universal adoption. Other protocols—Secure Electronic Transaction, Secure Hypertext Transfer Protocol, Microsoft’s Private Communications Technology, among others—have faded from use. Kocher is unsure whether this is a good thing, in that there is less fragmentation and more consistency, or a bad thing, because other protocols could be better suited to particular use cases.

Another lesson stems from the idea that certificate authorities whose public keys are embedded in a web browser, for example, must all be secure for the ecosystem to be strong. When Kocher was working on SSLv3, VeriSign was the primary certificate authority, and he did not expect there to be more than a few. Now, there are hundreds because economic and political pressures led browser makers to include many certificate authorities. The economic pressures of having so many certificate authorities meant that they had little budget for diligence when issuing certificates. “There was no incentive to do a good job . . . Everything economically that could go wrong did,” Kocher said, adding that in some cases certificate authorities found their only profitable option was to issue unauthorized certificates to attackers wishing to impersonate legitimate websites. This story demonstrates how the success of cryptographic agility depends not only on sophisticated, “interesting math” (which tends to get more attention), but also on a mix of politics, economics, and policy.

A final lesson is the importance of implementation. To put it plainly, Kocher stated, “Implementation mistakes are the number one enemy and have been the absolutely overwhelming source of problems.” When Kocher reviews a new security method, he looks for common errors that could occur during implementation and be used to bypass the security, such as bugs in Universal Serial Bus (USB) driver software and certificate parsing routines. He admitted to regret in using the X.509 certificate format in SSLv3. A cleaner certificate format could have avoided implementation mistakes but would have made SSLv3 adoption more difficult since X.509 was already in widespread use.

Piracy in Pay Television

Kocher described his work on a project to prevent piracy in pay television, starting with a brief history of the evolution of pay television technology. Early plaintext feeds were easily hacked by hobbyists. The next format, television set-top boxes, had a relatively secure single DES encryption system, but the hardware and key management were “terrible,”

Kocher said. The United States' legal responses eventually just drove piracy overseas, he noted, instead of addressing the technical holes that made piracy possible.

The next innovation was a removable security chip, present in many of today's set-top boxes, which creates a new key for every 30 seconds or so of video coming onto the television screen. However, if something is broken in the key-creation process (e.g., the chip is hacked), the only remedy is to mail the user a replacement card, which is expensive and logistically difficult. Kocher said his team has been deploying approaches that put agility mechanisms and tamper-resistant hardware in the video processing chips in the set-top box itself. It is an approach Kocher believes is working well, though he noted that its impending broader deployment will increase pressure on the new system and likely increase attention to other security risks that will need to be addressed such as recording video from displays.

Kocher said a key lesson from the television piracy experience is that criminals are agile, too, and that cryptography theory cannot predict all of the practical problems that will be encountered in real-world use. Pirates were able to hack the cryptographic systems in place and to continue accessing video despite the replacement-card system. For example, replacement cards often had to be readily available for consumers whose cards had been hacked, and replacement cards made without knowing the "hack" typically had the same vulnerabilities as the ones they were replacing. Because of issues like this, Kocher and his team focused heavily on preventive methods instead of relying solely on agility methods. He called the preventive approach a technological success, though it made existing vendors unhappy because they had made a profit from replacement cards. "The idea that you might have a system that does not need replacing on their planned revenue schedule was extremely threatening for them," Kocher said, offering another example of economic interests gaining the upper hand in security decisions.

It also turned out that the pay television operators were subsidizing the cost of the set-top boxes and, unwittingly, making it easy for piracy to continue. A box including the security card cost about \$200 to make but was being sold to customers for about \$50. In this situation, Kocher claimed, the pirate could buy the box with the included card, "throw the box away, hack the card, and sell it," making a profit. Kocher said this economic problem underscores the point that agility architectures can create risks that require non-agility responses. The card's vulnerability to pirates has led some designers to eliminate the cards (and card slots) altogether.

Piracy of Content on Optical Discs

Kocher then described his experience with preventing piracy of content sold on optical discs. The original digital versatile disc (DVD) format and players each had some cryptography, but neither had any agility to deal with their inevitable vulnerabilities. Pirates

were able to hack the players in a way that could not be fixed, leaving only unappealing choices: allow all copyrighted content issued on DVD to be pirated or issue a massive recall of DVD players, an option Kocher described as “trying to control shoplifting by using nuclear weapons.” Studios and DVD manufacturers never did “push the button,” and never could have, because “there was so much politics involved that nobody could actually decide what to do.” The result, he said, “was security that failed in some pretty catastrophic ways.”

In this environment, Kocher’s team focused on securing the Blu-ray format and created a system where pieces of security software could be delivered on the disc itself. This approach was a hybrid of copy protection schemes from the 1980s and modern

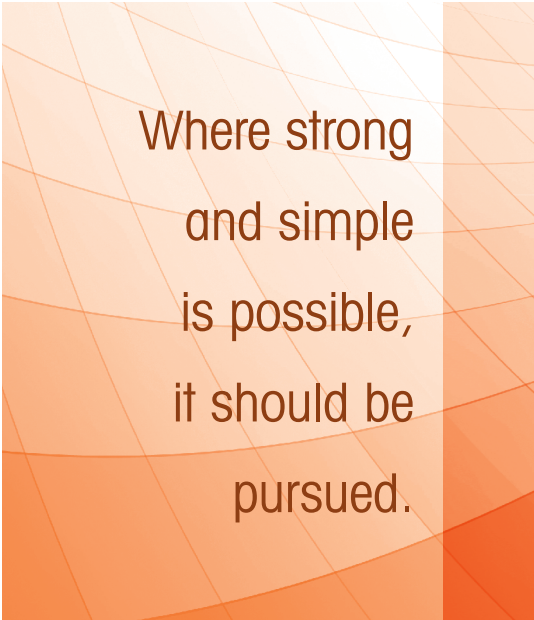
cryptography that, when a disc was inserted, required players to run a specific set of cryptographic algorithms in order for the disc to play. This system meant that it was possible for new discs to bring new security code to mitigate attacks that had appeared.

In addition to helping address vulnerabilities in players, the code on the disc can also embed tiny changes in the video stream that can be analyzed forensically on pirated copies. This information can help pinpoint a pirate’s methods and craft a suitable response to them.

Despite these advantages, Blu-ray players had many vulnerabilities. As a result, the renewability system became what Kocher described as “a whack-a-mole system.” In addition, the business model of pirates

changed. With DVD, once a free circumvention tool was released, it never needed to be changed and pirates had limited revenue opportunities. With Blu-ray, piracy tools needed frequent updates, so hackers (usually located out of the reach of U.S. law enforcement) adopted a service model that provided them with recurring revenue.

When discs with a new security method were released, it typically took time for attackers to discover and exploit it, but they eventually did. Hollywood, Kocher said, viewed this as beneficial nonetheless because its business model favors the brand-new movie over the months-old one. However, this security timeline is poorly suited to paid software or other data meant to be used over time, and it has serious implications for long-term classified data. Kocher concluded by pointing out, “You cannot un-steal the information that is leaked.”



Where strong
and simple
is possible,
it should be
pursued.

Agility Versus “Strong and Simple”

William Sanders, University of Illinois, Urbana-Champaign, opened the discussion by framing the issue as a tension between agility, which is necessarily going to add some complexity, and “strong and simple” security solutions. He questioned whether a strong and simple approach is even possible in many contexts. Kocher said that a simple approach is possible and beneficial but only within a narrow set of problems, such as cryptographic algorithms themselves. Kocher also suggested looking to older systems for ideas. For example, an old personal computer with a floppy disk drive could easily be reverted to a known (presumably good) configuration simply by turning the machine off and then on again. Creating a similar property in some of today’s systems should be achievable, he said.

However, Kocher suggested that a strong and simple method is likely not appropriate or achievable for complex systems of distributed databases, such as those involved in the Office of Personnel Management breach. That said, Kocher emphasized that where strong and simple is possible, it should be pursued. While the Blu-ray solution may seem somewhat complicated, he noted that the code required thousands, but not tens of thousands, of lines of code, making it relatively strong and simple. But the economics and use cases of Blu-ray players made it impossible to build a system that would be truly impenetrable.

While there is a tension between the two approaches, Kocher said they are both necessary. Prevention is obviously preferred because a theft cannot be fully undone, but one also has to plan for failure. He suggested that equal attention should be paid to preventive measures *and* agility, as opposed to the situation he sees today, where most of the attention (and resources) are spent on repairs *after* security breaches.

Government and Infrastructure

The second section of the workshop featured two speakers, Kerry McKay and Richard George, with extensive backgrounds working in the area of cryptography for the U.S. government. They covered the government's use of cryptography and its standards-setting process, the evolution of cryptographic technology, and current and future challenges.

HOW THE NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY THINKS ABOUT CRYPTOGRAPHY

Kerry McKay, National Institute of Standards and Technology

Kerry McKay is a computer scientist in the Computer Security Division at the National Institute of Standards and Technology (NIST). Her talk focused on the process NIST uses when creating cryptographic standards.

Cryptographic Agility and Interoperability

McKay opened by outlining three facets of cryptographic agility: (1) the ability for machines to select their security algorithms in real time and based on their combined security functions; (2) the ability to add new cryptographic features or algorithms to existing

hardware or software, resulting in new, stronger security features; and (3) the ability to gracefully retire cryptographic systems that have become either vulnerable or obsolete. McKay defined “interoperability” as the ability to communicate and exchange information between systems.

Pursuing the double aims of agility and interoperability works in some ways but not in others, she noted. Supporting a wide variety of algorithms for interoperability can increase a machine’s agility. For example, older devices can be updated with new algorithms that allow them to communicate securely with newer devices. However, interoperability can also complicate agility. It makes it harder, for example, to remove outdated protocols or algorithms such as Rivest Cipher 4 (RC4) and Secure Sockets Layer (SSL) 2.0, which should be retired. Some legacy systems cannot be updated because of hardware restrictions. A user might not be willing to pay to have an older machine properly secured or to give up a familiar operating system (such as Windows XP) that manufacturers are no longer updating. As a result, interoperability sometimes means supporting algorithms that are not very secure.

Reiterating a point Paul Kocher raised, McKay noted the importance of recognizing the potential hazards of implementation flaws. Supporting agility and interoperability requires more software, but that increases the number of potential security vulnerabilities and bugs, she said. In constrained environments, such as those required to manage small radio frequency identification (RFID) tags, there is not always room for all the security a device might need, making it especially important to employ the right security approach. Supporting weaker algorithms instead of retiring them can also lead to what are known as “downgrade attacks,” in which hackers are able to find and exploit known weaknesses in servers that still support these algorithms.

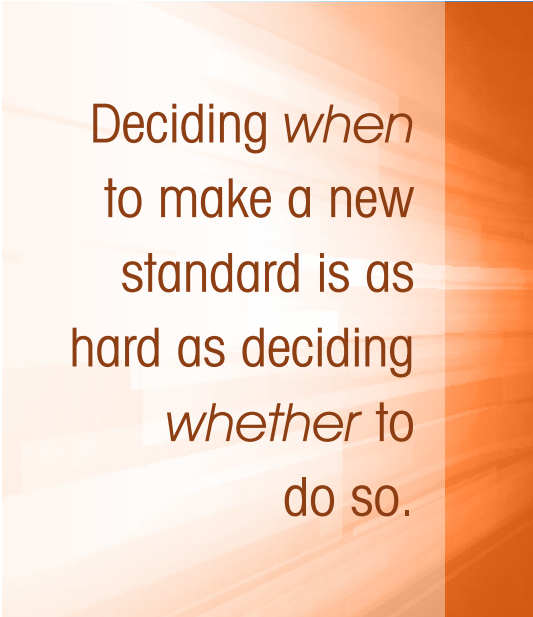
The National Institute of Standards and Technology Process

McKay turned to the standards-making process at NIST, which seeks to balance agility and interoperability with security for non-classified government systems. NIST’s “Transitions: Recommendations for Transitioning the Use of Cryptographic Algorithms and Key Lengths” (SP800-131A) outlines which cryptographic algorithms are allowed, allowed with conditions, or disallowed. For example, Data Encryption Standard (DES) is not considered secure enough to encrypt new data, but older data can be decrypted via DES with a warning about its insecurity. In the case of two-key triple DES, NIST allowed its use for encryption only until the end of 2015 and only for limited amounts of data.

In another example, NIST recommends against using Secure Hash Algorithm-1 (SHA-1) for digital signatures. When SHA-1 is used for creating digital signatures on short-lived parameters within a protocol, such as ephemeral keys in Transport Layer Security (TLS), there is a very small window of opportunity for an attacker to disrupt that

process. The threat changes when using SHA-1 in a certificate for server authentication. The data that are signed have value for a longer period of time, allowing more time for an attacker to find a hash collision and create a fraudulent certificate and increasing the potential threat.

McKay conceded that NIST was not quick to make new standards. It has a small, specialized staff (though NIST is, she noted, actively hiring cryptographers) and a strong focus on completing projects carefully and thoroughly. When NIST determines that a new standard may be needed, the institute holds workshops and meetings with aca-



Deciding *when*
to make a new
standard is as
hard as deciding
whether to
do so.

demics, government employees, industry leaders, and participants from related organizations like the International Organization for Standardization and the Internet Engineering Task Force. Through this process, NIST studies the available algorithms; determines if new ones are needed; and then develops new standards, adopts a standard that already exists, or holds a competition. The competition model has both benefits and drawbacks, McKay said. It worked well for Advanced Encryption Standard (AES) and Secure Hash Algorithm-3 (SHA-3), but competitions are time intensive and expensive to run. AES had 15 submissions and ran from 1997 to 2001. SHA-3 had 64 submissions and ran from approximately 2004 to 2015.¹ Because of these downsides, sometimes it is more helpful to focus on algorithms that

are already in use. This option works well for block cipher modes, which add features to block ciphers that have already been standardized, with faster timelines and lower implementation cost.

When NIST is ready to issue new standards, they are written up in a document that goes through a long internal and external review process. If it is a Federal Information Processing Standard, the document has to make its way up several management levels before being approved by the Secretary of Commerce, which adds more time and complexity. This long review process underscores the importance of being thorough and deliberate when creating new standards and explains why NIST cannot operate as nimbly as other entities might.

Those limitations, however, also mean that government systems have a high degree of interoperability because they are highly likely to have algorithms in common. Adding algorithms to the approved list could complicate that interoperability because

¹The idea for SHA-3 began in 2004 and the concept was finalized in 2015.

each new cryptographic system would have to be fully validated by NIST before it could be used.

McKay said it works well for NIST, and the federal government more broadly, to have general purpose primitives and modes for special features such as authentication or data storage. McKay listed the various standards that NIST recommends and uses: Secure Hash Algorithm-2 (SHA-2), SHA-3, 3DES, AES, RSA, Elliptic Curve Digital Signature Algorithm, Digital Signature Standard, and hash message authentication code. They also use block cipher modes of operation to achieve confidentiality, authentication, key wrapping, and format preservation. In addition, she said NIST is working on new hash function modes, tentatively named Keccak Message Authentication Code, TupleHash, and ParallelHash.

Deciding *when* to make a new standard is just as hard as deciding *whether* to do so. Sometimes vendors request that NIST incorporate a particular algorithm into its standards to improve their business prospects with the government, a suggestion that holds little sway with NIST. “In the end, our standards are geared towards the unclassified government IT systems and they cannot be driven by vendors,” McKay said. Sharing a story to illustrate this point, she said a recent draft document initially recommended three encryption modes. An issue was discovered in one mode, and it was left out of the final version. This mode was repaired, but it was no longer needed because the first two were sufficient. Adding it back would have made that vendor happy, but it would have cost taxpayer money and NIST time to do it. “It did not align with our mission, so we decided not to do it,” said McKay.

Because of the intensive process of creating new standards, longevity is a key concern for NIST. These standards should be built to last and possibly even to *outlast* the technologies that are being used today. “We have had AES around since 2001 and it is still going strong,” McKay said. “That is the kind of thing we like.”

Future Directions

McKay noted that newer devices are sometimes too small to have adequate security. Light bulbs and RFID tags, for example, are not typically being manufactured to be secure. NIST is actively researching lightweight primitives for these small devices, loosely known by the umbrella term “the Internet of Things.” For example, NIST could add AES or another strong security mechanism, but with current approaches this would come at the expense of speed or price. Quantum computing is also a concern for NIST, she said.

The institute is currently working to create modes to enhance functionality while using the same core primitives. As an example, SHA-3 includes the Keccak permutation, which could be used to give users more features with less implementation overhead.

Launching the discussion session, Steven Lipner, an independent consultant, asked what NIST was doing to smooth transitions from one standard to another when they inevitably change. For quantum computing specifically, McKay responded that NIST was looking at several different designs and putting out a call for new algorithms. Donna Dodson, NIST, suggested creating an algorithm that was resistant to both today's attacks and future quantum attacks, although it would present key management challenges. She added that it would be even better if such an algorithm could be completed and deployable *before* quantum computing became a reality. McKay noted that NIST does recommend transition periods in SP800-131A, including considering the time a vendor needs to anticipate the change to its business.

When asked by Matthew Green, Johns Hopkins University, whether NIST had plans to modernize its approval process for new algorithms, McKay and Dodson answered that to do so, NIST would need more personnel. McKay explained that the NIST team goes through the math and its proofs itself rather than outsourcing the work, which is partly why it takes so long. She expressed her belief that it is important for the institute to be involved in the technical aspects, in part because it is also NIST's duty to help policy makers understand the decisions that are being made.

Eric Grosse asked if NIST could adopt a management style similar to the one he used at Google, where he strongly encouraged creators to identify which old system would be shut down whenever a new one was initiated. McKay responded that NIST already uses a similar approach, citing SHA-3 as a result of the discovery that SHA-1 had problems. Because they knew it would take a while, they laid the groundwork fairly quickly. In case SHA-2 started showing the same mathematical weaknesses as SHA-1, NIST realized that it needed to go with a very different design. McKay also pointed to the core standards NIST recommends, which rarely have more than two or three options.

Dodson added that NIST does not have policing or enforcement power when it comes to its recommendations. When it no longer recommended SHA-1, some of the larger federal agencies had significant challenges figuring out where, and with which vendors, they were using this ineffective security mechanism, and it took some of them a full 18 months to replace it. McKay noted that a further complication is that some government websites must interact with the public. For example, there are some versions of TLS that are allowed because public-facing servers need to account for the security of the user's browser. TLS 1.0 is still allowed in this case, despite not being as safe as NIST prefers. "It is kind of hard to tell someone they cannot go to [the] Social Security Administration web page and log in because they have to update their browser and they might not know how to do such a thing," McKay explained. McKay closed by pointing out that creating government-to-government standards is much easier than interacting with the public. There, she said, "the water gets muddy really quickly."

CRYPTOGRAPHY THROUGH THE YEARS

Richard George, The Johns Hopkins University, Applied Physics Laboratory

Richard “Dickie” George, currently a senior advisor for cybersecurity at The Johns Hopkins University Applied Physics Laboratory, has had a long career in the field of information security. He spent more than 30 years at the National Security Agency (NSA), including 8 years as the technical director at the NSA’s Information Assurance Directorate, a capacity in which he often confronted problems of resilience and agility. He presented a history of cryptographic technology in the government sphere.

While businesses may balk at the costs of repairing security, the uncomfortable truth is that all cryptography does eventually break. Reflecting on 45 years in the field, George emphasized how essential, yet complex, the issues of cryptographic resilience and agility are and underscored the urgent need to continually work on these issues as technology evolves.

Early Cryptography

George began with an overview of VINSON, a voice encryption device for military radios. VINSON’s initial objective was to encrypt radio communication between a forward observer and up to six contacts. The cryptography behind VINSON went through a lengthy design and testing process, spanning nearly two decades from its initiation in 1957 to the system’s approval for use in 1976. The results have been lasting: “It is still secure as far as we can tell,” said George. “It has never had any modifications—that is a pretty good run.”

Because of the limited purpose of VINSON, interoperability was not an issue. Radios with VINSON were not intended to communicate with receivers on satellites, bases, or fighter jets. “That made it very simple to design only the bare minimum functionality into that system that we needed,” George said. Also, before 1973, software and computers were not considered secure enough to contain cryptography as it existed at the time, so VINSON was designed only for the realm of radio. The limited nature of VINSON-equipped devices’ functionality had the added benefit of keeping communication secure. “Functionality,” George cautioned, “is opportunity for the adversary.”

The “agility” mechanism of the VINSON system was strikingly different from how we think of agility today. Each cryptographic machine contained one or more boards that implemented its own cryptographic algorithm. Any problems were thus limited to the copies of that machine, and the boards could be modified or removed and replaced without impact on the functioning of other cryptographic machines.

Transitioning to the Modern Era

Eventually, as interoperability became an essential component of secure communication systems, more challenges arose. VINSON had few modes—plaintext and encrypted, on and off. The next generation of devices that would be required to interoperate with VINSON had 1,024 modes, almost all of which had to be secure. This dramatically increased the challenge of evaluating each algorithm and its implementation. George emphasized the difficulty of evaluating the implementation in particular because in addition to knowing the designer's intentions, one must also take into account a variety of unpredictable real-world scenarios. Underscoring the difficulty of this task, George noted that the NSA today is still evaluating VINSON's algorithm, 60 years later, just in case there are surprises inside. "Occasionally, you find things," said George. "When you do find them, you have to fix them or accept the risk," he added, noting that if there are openings, it is often impossible to know whether an adversary has also found them.

Today's technology has so much more functionality. Cryptography has also proliferated because increased functionality means there are more places to protect and more ways for data to be attacked. "In order to attack cryptography back in the '70s, you had to attack the cryptography," George said. "Today, you go around the cryptography." Availability is also key to today's technology, but early cryptography was not designed to accommodate availability. Integrity, authentication, confidentiality, and non-repudiation were the traditional aims.

The Problem of Legacy Cryptography

Building on a theme raised earlier in the workshop, George commented on the problem of legacy cryptography that remains in software or hardware after it has become obsolete. This typically happens either because new devices still have to be able to talk to older ones or because there is still information stored and encrypted with those older algorithms. These and other factors mean that in many cases old cryptography can never be fully retired. Where legacy algorithms are in use, they present a risk because adversaries can bypass the newer, stronger cryptography and attack the older, less secure algorithms. Preventing backward compatibility and forcing old cryptography to break can mitigate the issue, George said.

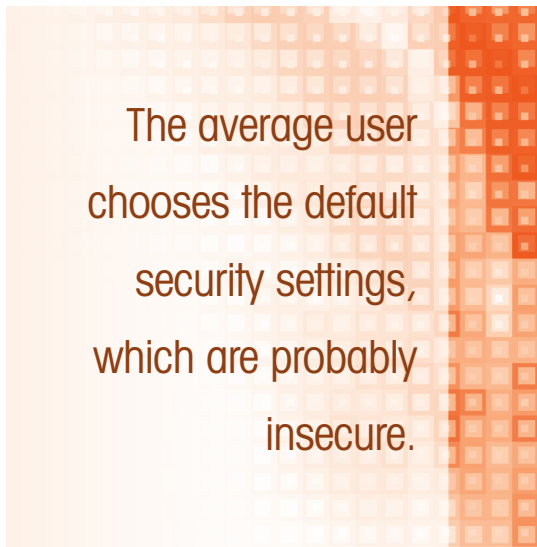
In the discussion following George's presentation, Bob Blakley, CitiGroup, Inc., noted that his mentor used to say that code was akin to "original sin": Every line you write stays with you and your descendants forever. Therefore, perhaps instead of erasing old algorithms, as George suggested, participants should instead think about how to live with these mistakes, since the more likely scenario is that they will *not* be retired. George replied that at some point, technologies do become obsolete, such as vacuum tube televisions and rotor encryption machines. Butler Lampson, Microsoft Corporation,

weighed in by paraphrasing a suggestion he attributed to Alan Kay. Computers should be like tissues, he said: “You use it once and throw it away.” Such an approach could greatly simplify the security required.

Properly storing information is essential to government work and required by law in certain situations. George shared an anecdote in which retrieving stored information proved to be nearly impossible, illustrating that these requirements do not always ensure that stored information will be retrievable—just that it will be stored.

International Dimensions

George described some of the international factors that influence cryptography. Foreign governments sometimes have very different standards and motivations than the United States. Some countries do not value citizens’ privacy in the same way that the United States does, and they are changing or adapting secure cryptography for their own ends. For example, some governments may refuse to use public algorithms and instead require the use of their own cryptography in systems, without sharing that algorithm or allowing



The average user
chooses the default
security settings,
which are probably
insecure.

designers to evaluate it or its implementation. In such cases, said George, “We are going to have to trust [that government] and trust that it has not done something to circumvent everything else that we have in there . . . You cannot possibly vet that algorithm.” Another wild card is randomization. Countries might require their own randomization, which can create ancillary issues. In this complex environment, the cryptography itself becomes the “simple” piece of the puzzle.

During the discussion, Deirdre Mulligan, University of California, Berkeley, asked George to expand on situations in which the requirements of foreign governments may be at odds with citizens’ privacy or other rights. While diplomacy is important, she said, citizens are often unaware that there is a security choice at all and end up using an insecure setting by default. George agreed that the average user chooses the default security settings, which are probably insecure. Mulligan clarified her question to ask if other governments, for example China, could create transparency in their information security process or at least allow their users to understand what level of privacy they actually have.

George suggested that the situation is difficult from any perspective. Other governments make their own decisions about what cryptography is allowed to be used and sold and are unlikely to be persuaded to change their policies. For the same reason, it would be hard to explain to, say, Chinese users what risks they are taking using software whose

cryptography was likely amended. Unfortunately, in foreign countries, there is not much that can be done. “You do not hold a winning hand in trying to protect people when the government does not want to protect them,” George explained.

Preparing for Quantum Computing

George noted that the government is still studying VINSON because it is possible that holes may yet be revealed. Today’s much more complex cryptography, such as RSA cryptography or quantum key distribution, involves distinctive risks. There is a lot of cryptography in use today that is not fully understood and can perhaps never be fully secure, George argued. An approach known as quantum key distribution might be considered safe, for example, but George asserted that every implementation of quantum key distribution so far has been shown fairly quickly by academic researchers to be insecure.

Quantum-resistant cryptography is so little understood that it would require years of study—time that we really do not have, George said. The security of government and personal data is at stake. Classified documents, financial information, and health records all need to be protected as well. George pointed out that health records hold information that does not change, such as a person’s blood type or medical history. When a credit card account is breached, it is fairly easy to receive a new card and a new account number. “But if they steal your health records, you cannot change them that easily,” said George. “These are the kinds of things we have to understand. We have to be ready.” Quantum computers represent a real and urgent threat that must be addressed, he said.

In the discussion, Steven Lipner asked George to imagine that quantum computing was real and could break the widely used 2048-bit RSA keys. In that situation, how would he advise the President? George said his advice would be first to go back to an older system, such as symmetric key distribution, although he would prefer not to need such a stop-gap. It would be far better to be ready and prepared for quantum computing, he said. The older systems would be merely backup communication systems, like Morse code and sextants for navigation on ships. Lipner reflected that many businesses do not have any backup plan, which could cause big problems both for them and for their customers.

Addressing Current Weaknesses

John Manferdelli, Google, Inc., asked George if insecure hardware, which is most of what people are using today, is a “catastrophic problem.” George described the issue as one of risk management, and the answer would depend on what the system is, who the adversary is, and how bad a data breach would be. The online banking industry might be able to live with some of the risk of quantum computing, but the nuclear weapons system probably could not.

George emphasized that the nature of our adversaries has changed. In the Cold War years, enemies' motivations were clear and they followed "the rules," both of which are no longer the case. Key questions have to be considered: "Who is going to have access to that quantum computer? What are they going to be able to do, and what are you worried about?"

Referencing the focus on quantum-resistant cryptography, Paul Kocher, Cryptography Research Division, Rambus, Inc., questioned whether those more "hypothetical" challenges should really be the priority or if the more everyday bugs and repairs—which we know are problems right now—should be attended to first. George agreed that today's systems are definitely in need of repair and that part of the problem is that we rely too much on users to protect their computers and software. In a car, he noted, there are seatbelts and warning systems that protect the occupants. "We ought to have the same kind of regulation that says that the computer ought to protect the user rather than the user protecting the computer," George asserted. In the context of the security problem known as buffer overflows, George suggested fixes must be made in hardware because software is too extensive and diverse.

George emphasized how critical it will be to know which adversaries have access to quantum computers and what types of extremely important information must be protected from this threat. However, the vast majority of attacks happening today involve much more run-of-the-mill adversaries who can be defeated through better user behavior. Citing a statistic that 91 percent of security attacks in 2015 came from phishing—a user clicking on a link that unwittingly let an adversary in—George asserted that better system design, not public education or training, is needed to help prevent these sorts of breaches. "You really cannot train them not to because you are talking about 4-year-olds and 90-year-olds . . . That training is not going to work. You have to protect them. Let the computer not let them do dumb things," he said.

Standards and Security Implications

The workshop's third session focused on standards for cryptographic agility as well as the security implications for various levels and types of agility. Russ Housley described the process and perspective of the recent Request for Comments (RFC) 7696 guidelines from the Internet Engineering Task Force, and David McGrew drew on real-world experiences and data to highlight lessons learned and future directions.

RFC 7696: GUIDELINES FOR CRYPTOGRAPHIC ALGORITHM AGILITY AND SELECTING MANDATORY-TO-IMPLEMENT ALGORITHMS

Russ Housley, Vigil Security, LLC

Russ Housley, founder of Vigil Security, LLC, and past chair of the Internet Architecture Board (IAB), presented on *RFC 7696: Guidelines for Cryptographic Algorithm Agility and Selecting Mandatory-to-Implement Algorithms*.

RFC 7696, which is also known as Best Current Practices 201, was initiated by IAB under its Privacy and Security Program. After the early draft development and initial review and comment process, the project was transferred to the Internet Engineering Task Force (IETF) Security Area Advisory Group. Before publishing the document in November 2015, IETF shepherded it through a broader review process and achieved consensus.

The goal of *RFC 7696* is simple to state but not so to achieve: to ensure that security protocols can migrate from one algorithm or suite of algorithms to a newer, stronger one when needed. Tackling this, Housley said, requires viewing the problem from two perspectives: that of the protocol designer and that of the protocol implementer.

Protocol implementers need to be able to add a new algorithm, which requires modularity that would not otherwise be needed, and they need a way to detect if the new algorithm has been successfully added, which is something many protocols currently lack. “We are hoping that one of the things that will result from this guidance is that we will get that capability,” Housley said.

The protocol designer has a different goal: to identify which algorithms are old, which are new, and which are mandatory to implement to achieve interoperability. The answers to these questions change each time a new algorithm is added, which increases confusion. A registry of identifiers for all known protocols, algorithms, and algorithm suites would help both designers and implementers, Housley said, noting that popular consensus is that such a registry be created by the Internet Assigned Numbers Authority.

Selecting Mandatory-to-Implement Algorithms

Housley emphasized that an important role of *RFC 7696* concerns the selection of algorithms that are mandatory to implement and necessary for interoperability. Mandatory-to-implement algorithms should be included in any implementation of a particular protocol, although there can be debate over which algorithm to select. For example, there is currently a debate over whether to default to a probabilistic signature scheme (a method for constructing an artifact before applying the signature operation) as part of the Transport Layer Security (TLS) 1.3 protocol. Either way, once the decision is made, all implementations must include the common algorithm in order to achieve interoperability and to be compliant.

Prompted by Bob Blakley, CitiGroup, Inc., Housley clarified that if the mandatory-to-implement algorithm is *not* implemented, the product would be considered non-compliant with IETF standards, though he noted that IETF has no policing power to enforce these standards. “It is more of a ‘Hall of Shame’ kind of a consequence,” he said.

Although IETF provides guidance that allows for either choosing algorithm suites or taking a piece-by-piece approach (in which a cryptographic mechanism is built from a collection of known elements), Housley noted that sometimes a piece-by-piece approach can result in a mechanism that looks reasonable but is not actually secure. Housley stressed the importance of building a cryptographic mechanism in which each piece is roughly equal in strength. A weak key agreement paired with a strong cipher, for example, is still vulnerable to attack at its weakest point—another downside to a piece-by-

piece approach. Echoing a sentiment expressed by other speakers, Housley emphasized that simple implementations are essential to strong security.

Ideally, Housley noted, when a new, stronger algorithm is developed and introduced, the older algorithm is retired. But it takes a lot of work and coordination to make this happen; there must be a mechanism in place to reject the older (often flawed) algorithm before the new one is rolled out to all implementations. The challenge is compounded when an algorithm is implemented in hardware. In that case, a piece of equipment such as a chip or board has to be replaced (rather than distributing software patches over the network). “No matter what we do,” said Housley, “transition is going to be hard.” And when interoperability fails, the one who turns off the old algorithm becomes “the bad guy” who is blamed when the two systems are no longer able to work together.

The IETF process of selecting mandatory-to-implement algorithms was designed to “let the experts in this technology do the picking,” Housley said. The number of algorithms or implementations is also important. If there are too many algorithms or implementations available, several may be rarely used; if these have flaws or breaches, they can go unnoticed, and thus unfixed and exploited, for a long time. On the other hand, if only one algorithm or implementation is chosen and it turns out to have a flaw, that is clearly a problem, too. *RFC 7696* therefore recommends choosing two algorithms for implementation. The second choice can act as a backup if the first is found to be flawed.

During the discussion, Blakley inquired about what constraints might be imposed by fixed-length fields in hardware and protocol headers in the context of agility. Housley responded that in his experience this is less and less of a problem as it gets easier to accommodate variable field lengths. Although the field length might affect the speed of a communication, he said, it is not likely to drop the communication altogether, as might have been the case in the past.

Opportunistic Security and the Need for Deliberate Security Decisions

RFC 7696 came about when the idea of “opportunistic security” was gaining traction. Under this model, communications are encrypted, possibly without any authentication. Basically, any encryption technique that is common between the implementations is used, which increases the effort for an adversary to intercept communications. In this sense, opportunistic security makes pervasive, passive surveillance difficult because many users employing a weaker algorithm or shorter keys can force an entity trying to do covert surveillance to break all of those endpoints, which is a difficult and time-consuming task.

In the discussion, Eric Grosse, Google, Inc., said that when most communication was clear text, he was in favor of opportunistic security. However, he now opposes it for two reasons: (1) people can become overly reliant on it and neglect true security; and

(2) state actors or enterprises can take advantage of the relative weakness of opportunistic encryption to do their own content injection.

Housley replied that he does believe opportunistic security increases the amount of work required to conduct surveillance or push content. For example, if a weak cipher is being used, decrypting it still takes time. However, he agreed that data are not well protected with opportunistic encryption, and he cited the difficult situation faced by communications carriers. They want to offer their users the fastest service, while also keeping communication secure. There is currently a debate between the IETF and the Groupe Speciale Mobile Association about how wireless service would be affected if everything becomes encrypted. Email and web encryption might be hardly noticeable to users, creating only tiny delays in the transmission of information, but users “certainly would notice if their voice call had sporadic sputters in it.”

Housley said that a mechanism is essential to determine what needs encryption and what does not. A one-bit covert channel might be enough to enable the right distinctions, he suggested, although he noted that many firewalls currently being used would need to be updated.

It is also crucial that cryptography experts be actively engaged in designing and evaluating systems. Prompted by a question from Donna Dodson, National Institute of Standards and Technology, Housley pointed to instances where cryptographers were not involved, but they could have been of use. For example, Wired Equivalent Privacy (WEP) was flawed in ways that would have been relatively obvious to a cryptographer, but “no cryptographer cared to look” because WEP used 40-bit keys, which were already known to be breakable. When a 128-bit key variant was introduced, the system was still highly flawed because the security decisions had been made by a committee with little cryptographic expertise. “I would argue that we need educated people involved in the protocol design to avoid another WEP,” Housley said.

The International Context

Housley touched on how the international context influences standard-setting. Offering an example from his past role as IETF Security Area Director, he recalled receiving a complaint from Russian financial institutions that there was no support for the GOST algorithms (an alternative to Data Encryption Standard) in the existing TLS protocol. They wanted to use TLS to secure online banking, but the Russian regulations required the use of GOST for all financial transactions in that country. As a consequence, the entire country was unable to bank online. Housley and Steven Bellovin, the two IETF Security Area Directors at the time, agreed to tackle the problem. “I was not willing to be the guy that said the Russians cannot do online banking,” Housley said.

Peter Swire, Georgia Institute of Technology, asked how many countries have national encryption standards and how that landscape affects agility. Housley noted that, in addition to Russia and China, many other countries including Korea and Japan have these standards. Each is different; some focus only on the encryption algorithm (as in the case of Korea's SEED algorithm) and others include the whole suite of algorithms, key management, digital signature, hashes, and so on (as in the case of Russia's GOST family of algorithms).

Different countries have different priorities when it comes to investing in cryptography and algorithms, and technologists have no control over these political decisions. "All we can do is come up with a way that lets [the algorithms] be used in the policy environment where they are required," said Housley.

Noting that this diverse international context creates modularization of security mechanisms, Swire asked whether these differences might be a "blessing in disguise." Housley categorized it as a double-edged sword: while modularity has its benefits, configuration around national algorithms makes it harder to maintain interoperability and creates a tough situation when flaws are found. Then, the question becomes how to change the configuration or implementation to eliminate the flawed module without losing interoperability.

Paul Kocher, Cryptography Research Division, Rambus, Inc., raised the ethical side of the international context. Given that governments have differing reasons for imposing requirements and that sometimes those

reasons are at odds with the ability for individuals to obtain adequate security, he asked about the role of standard-setting bodies like the IETF: Do we give these governments the cryptography (and "back door") they want, or can we force them to accept something that "gives everybody well understood security properties?"

In response, Housley said that first, the mandatory-to-implement algorithm needs to be as strong as possible so as to give all Internet users a baseline level of security. Beyond that, each country is operating within its own political context, which is beyond the purview of the IETF. "I think we have to accommodate the local decision—I do not see how we cannot," he said. A possible balance could be that local identifiers recognize the mandatory-to-implement algorithms even if they do not implement them. He also noted a downside to refusing to comply with international requests. If he had refused the Russians' request regarding GOST and the TLS protocol, someone would likely have built

The mandatory-to-implement algorithm needs to be as strong as possible to give all users a baseline level of security.

an alternative TLS, probably with flaws, to accommodate the Russian demand for GOST. That kind of “forking,” Housley said, is harmful to the Internet overall.

Building on this point, Fred Schneider, Cornell University, noted that while one cannot necessarily prevent a government from acting according to its best interests, the IETF could still benefit users by requiring transparency. Transparency would allow people to see how secure the algorithms are before making their decisions. Such transparency also could discourage the creation of intentionally insecure algorithms. Housley said that the IETF has required that certain specifications be readily available for review, and some nations have gone even further, translating their algorithm specifications to English so that the IETF and other standards organizations can make their own judgments.

CRYPTOGRAPHIC AGILITY IN THE REAL WORLD

David McGrew, Cisco Systems, Inc.

David McGrew is a fellow in the Advanced Security Research Group at Cisco Systems, Inc. While cryptographic agility is broadly accepted, it is not broadly understood, he said. Suggesting that there are in fact different types of agility, he structured his talk to focus first on principles, then on real-world experiences, and finally on conclusions to inform future efforts.

Principles Relevant to Cryptographic Agility

McGrew began by highlighting what he sees as key principles related to cryptographic services, implementations, and agility. The first is that agility is essential for protecting against future threats and supporting backward compatibility. McGrew acknowledged quantum computing as an important threat but emphasized that it is not the only one, underscoring the need to be “future proof.” Agility is also essential for implementations, not just algorithms, he said.

A second principle is a non-technical one: customers should be able to choose what cryptography they use. He referred to Housley’s story of Russian online banking as an example of this idea. Cisco, as a multinational company, must balance support for international standards with support for the needs of its international customers. “We do not want to force any particular national agenda,” he said. For example, Cisco supports Japan’s use of its own national cipher, Camellia, as long as Japanese customers are willing to bear the economic costs of that decision. A related principle is that one country should not be able to force its cryptographic choices on the rest of the world, McGrew said.

The final principle is that complexity should not be forced upon users. Agility can be complex, as Paul Kocher outlined in his talk. “There is a concentration of interests and

a diffusion of cost,” McGrew said. He continued that if any country wants to add cryptography to the current standard to increase agility, that act increases the complexity for all implementers, testers, users, and policy makers, resulting in a “hidden cost” each time a new option or cipher is added. “I think this is a really important point that might get lost when talking about the benefits of agility,” McGrew said.

Understanding the Real-World Context

Cryptography is implemented in many different places in today’s systems. The level of agility that is appropriate or feasible depends on the context. McGrew described how hardware, field programmable gate arrays (FPGAs), operating systems, applications, and scripts can be arrayed on a scale ranging from most conservative/least flexible to most agile. In hardware, the cryptography is built in, but with FPGAs, there is slightly more flexibility. Operating systems have even more flexibility, applications can be very agile, and scripting languages such as JavaScript offer tremendous agility.

It is important to keep this spectrum in mind when designing cryptography to be agile or conservative, McGrew said. In his view, hash-based signatures can provide the best security against advances in cryptography, potentially even against quantum computing. He emphasized the importance of considering how long the equipment or product is expected to be used. Being conservative is more important than being agile in the context of products that are expected to be in the field a decade or more, he said, pointing to devices in the Internet of Things as an important example.

Elucidating the Different Types of Agility

McGrew posited that there is not one, but three types of agility: algorithm agility, protocol agility, and implementation agility. Algorithm agility means being able to swap ciphers or algorithms in and out easily; often this is done by swapping in a new block cipher. While in some senses it is the easiest form of agility, the variety of algorithm designs makes it more difficult than it sounds. He pointed to GOST, a cipher with a 64-bit block, and Advanced Encryption Standard, one with a 128-bit block. “Swapping the two is not as easy as you might think,” he said. Differences in modes of operation also affect potential swapping.

McGrew defined protocol agility as moving to a new version of a protocol, such as 1.1 to 1.2 for TLS. Protocol agility can be easy or difficult, but in McGrew’s view, it is more important, in many ways, than algorithm agility.

McGrew defined the final type, implementation agility, as the ability to update or replace software found to have a security flaw. This might not seem the same as cryptographic agility, but McGrew argued that if the user can bring a new implementation

himself, through Debian Linux apt-get or Windows Update, that counts as a situation requiring agility.

Lessons Learned from Discovered Flaws

Pointing to an analysis he conducted of OpenSSL common vulnerabilities and exposures (CVEs), McGrew described five categories of flaws: (1) algorithm flaws, including block ciphers and cryptographic primitives; (2) protocol problems, meaning fixes that require changes to the protocol; (3) side channel attacks, where secret keys leak out; (4) padding attacks, which may overlap protocols and implementations; and (5) implementation flaws, where there is a bug in the code that is often not revealed until it is too late to

Although agility
allows for known bugs
to be fixed quickly,
“fixes” increase
complexity and run the
risk of introducing yet
more flaws.

rewrite it. Of CVEs logged from 2002 to 2016, implementation flaws accounted for far and away the greatest number, findings that underscore Paul Kocher’s concern over implementation flaws.

The analysis also revealed what McGrew categorized as “a horrifying number” of flaws introduced when trying to fix previous flaws. Although agility allows for known bugs to be fixed quickly, all of these “fixes” increase complexity and run the risk of introducing yet more flaws. “There may be an implementation bug in the fix, or somebody did not think the fix through,” McGrew said. “I worry a lot about complexity.”

CVEs are not the only measure of successful security. An analysis of the use of network algorithms and key sizes revealed that obsolete cryptography is still

available and in use, he said, “including some traffic that really should not be using it.” How to get people to stop using such obsolete ciphers is “a fascinating question,” he said. With TLS up to version 1.2, he continued, it is possible to block particular ciphers known to be insecure, perhaps through a “smart rule” that denies connections on the basis of poor security. However, as Kerry McKay had noted in her presentation, it would not necessarily be fair to block a senior citizen from accessing the Social Security Administration website when the person might not know how to do that. “That is a really hard problem,” he said.

Data on client key lengths also revealed that very few people were using optimum key sizes to maximize security, a finding that surprised McGrew. In addition, McGrew expressed serious concern about the large number of people using software and hardware that is no longer secure or supported by the manufacturer. Another problem is that the people who originally bought, sold, installed, or configured a piece

of software may no longer be available to answer questions or make repairs for the organization that is using it.

Looking Forward

Looking ahead, McGrew noted the importance of fungibility—the ability for security components to be swapped easily. Block ciphers, he said, are fungible because they have a simple interface. Standards regarding authenticating encryption, for example, should also encourage fungibility.

He also posited that the rapid pace of generating the new TLS 1.3 standard was making it difficult for engineers to design for better agility, though he noted that it could be debated whether or not it would be worth slowing the deployment of TLS 1.3 for this purpose.

In closing, McGrew suggested that “implementation agility is the most important thing of all,” and implementation is where security needs to be as conservative as possible. In response to a question from Bob Blakley, McGrew elaborated on this point, arguing that system integrity should be a constrained, conservative area because it is best to have a small, trusted computing base. In part, this is why he supports hash-based signatures. Later in the discussion, Eric Grosse agreed that such signatures are the best bet for firmware updates because they are expected to be solid for the many years that firmware lasts.

Agility in the Context of Data at Rest

Tadayoshi Kohno, University of Washington, raised a question about the agility context for data at rest as opposed to data in transit. McGrew hypothesized that a storage-bounded model could work to keep stored data secure while it is deencrypted away from a weak security system and reencrypted with stronger security. Russ Housley added that a working group known as Long-term Archive and Notary Standards was looking at this question in terms of the security of digital signatures, but he did not know whether it had considered confidential stored data.

Noting that he is struggling with this issue on a design right now, Grosse said his team’s approach is to encrypt stored data on discs with fairly conservative symmetric ciphers. For metadata, which is a smaller amount of data, the team is using public-key algorithms that are more agile and likely to change in the face of a post-quantum computing world. Assuming that the current cryptography is secure enough, he estimated that this system provides more agility to reencrypt data as necessary, although it has not been proven. Housley shared that he has seen a similar approach work, but not for changing algorithms stored on discs with encrypted data.

Envisioning a Worst-Case Scenario

Steven Lipner, independent consultant, speculated about how it might be possible to design for a potential catastrophic future event, whether it is a quantum computer breaking all cryptographic code or another sort of catastrophe that could prompt the failure of an algorithm that we rely on, creating global computing chaos. “I do not think we can get away with ignoring it or hoping it will not happen,” he contended. Emphasizing the importance of implementation agility, McGrew said that implementation agility can complement algorithm agility when interface designers anticipate future flaws, whether in the anti-replay, freshness checking, padding, or another aspect of cryptography. Whatever it is, it needs to be properly addressed and easily replaceable before such a flaw is detected, he said. With true implementation agility, deploying new code offers a lot of flexibility to fix the problem correctly, without hastily plugging a leak and introducing a new flaw. Lipner argued that McGrew was envisioning the fairly quotidian experience of finding and fixing a flaw, whereas Lipner was speaking of a more extreme event. At some point in the future, Lipner hypothesized, “there are going to be some algorithms that are not part of the implementation you are going to want to replace. You are going to have to interface with the implementation [. . . and . . .] manage things at that interface,” which is, perhaps, a far more challenging task.

Engineering at Scale and User Implications

Workshop participants next tackled various aspects of cryptographic agility in practice. Matthew Green of Johns Hopkins University offered a case study of benefits and drawbacks of agility mechanisms in the Transport Layer Security (TLS) protocol. Google's Adam Langley explained agility in the context of extensibility, touched on the international context, and explored how retiring outdated security mechanisms affects users. Sara "Scout" Sinclair Brody of Simply Secure offered a perspective informed by the field of user-centered design, explaining how security and agility can be enhanced by better defaults, communication, education, and transparency—not only for end users, but also for developers themselves.

TRANSPORT LAYER SECURITY AND THE DOWNSIDES OF AGILITY

Matthew Green, Johns Hopkins University

Matthew Green is an assistant professor at the Johns Hopkins Information Security Institute and also writes a well-known cryptography blog titled "A Few Thoughts on Cryptographic Engineering."¹ Like other speakers at the workshop, he offered examples of the benefits of agility (which he defined as having the ability in place to react quickly and

¹The website for Green's blog is <http://blog.cryptographyengineering.com/>, accessed November 18, 2016.

appropriately to change), but he also highlighted some drawbacks. He used the frequent attacks on the TLS protocol as a case study.

When Agility “Saves the Day”

Green provided examples of how agility mechanisms have saved TLS over the years. Today, he said, “We are so used to TLS breaks . . . It has become a joke in our community.” But when the Browser Exploit Against SSL/TLS (BEAST) attack on TLS was first documented in 2011, it was “the beginning of an era.” In response to the attack, most users took advantage of the protocol’s built-in agility to move over to the Rivest Cipher 4 (RC4) stream cipher. However, RC4 was later found to be itself insecure and therefore a poor defense against BEAST attacks. In addition, the BEAST designers introduced another vulnerability called Compression Ratio Info-leak Made Easy (CRIME), which went after the preprocessing compression instead of attacking algorithms directly. Unfortunately, although cryptographers were theoretically aware of this weakness, those deploying and building servers did not know about it, and CRIME was able to decrypt TLS communication fairly quickly. When CRIME became known, it was contained by turning off compression on most TLS servers: “Agility saves the day,” Green summarized.

Newer, more secure cryptography platforms in subsequent versions of TLS brought mixed results. Cipher suites, authenticated encryptions, fast stream ciphers, and fast authenticated stream ciphers were all developed to increase security. However, Green explained, “it turns out that there were applications that we had not really considered.” RC4 was fast but not necessarily secure; to attain something fast *and* secure, designers are now looking at nonstandard cipher suites such as ChaCha20 and Poly1305 and considering whether it would be worth pursuing standardization of these suites by the Internet Engineering Task Force (IETF).

Agility as “Our Achilles’ Heel”

Green then turned to what he views as the drawbacks to agility, starting with the caveat that he does not quite agree with Richard George’s statement that people now try to find a way around cryptography instead of attacking it. He suggested that BEAST, CRIME, and the “padding oracle” attack be considered direct cryptography attacks. Arguing that many of today’s problems with TLS and Secure Sockets Layer (SSL) stem from decisions made in the 1990s, he said that even though our cryptographic algorithms and authenticated encryption have gotten significantly better, the built-in mechanisms have become “our Achilles’ heel.”

Green observed that a significant drawback in most systems is that legacy cryptography is not removed when new cryptography is added. As an example, Green said he was recently shown a paper describing vulnerabilities in several SSL stacks that involved

the “completely obsolete” export-grade (512-bit) RSA. Despite its obsolescence, “It turns out that at the time of this vulnerability coming out, about 30 percent of the Internet browser-trusted certificates were actually supporting export RSA,” Green said. Digging deeper, the researchers discovered that there had been an implementation vulnerability that allowed attackers to downgrade from a more secure protocol to export RSA, which could then be exploited—the Factoring Attack on RSA-EXPORT Keys CVE-2015-0204 (FREAK) vulnerability.

Noting that this same bug was found in three separate, and supposedly independent, TLS implementations, Green suggested that the bug may be in the protocol itself, rather than in the implementation. During the later discussion, Green speculated that



It is extremely
challenging to
prove today's
protocols secure.

one reason for the bug's persistence could be the persistence of features—and bugs—from previous versions of code that remain when a new version is created. Adam Langley, Google, Inc., added that the written specifications or instructions could inadvertently drive the implementer toward this bug. Eric Grosse, Google, Inc., noted that these examples underscore the importance of testing.

After discovering the vulnerability that allowed a downgrade to export-grade RSA, Green's team decided it would be wise to look at other ciphers supported in TLS/SSL and check for similar vulnerabilities. The team found a vulnerability, known as LogJam, that allows

attackers to downgrade from a strong protocol to a weaker export protocol, even when the client does not support export. The cause appears to be a key exchange message that has the proper parameters for the server to talk to the client but is missing an identifier that tells whether it is a normal or export protocol. Paul Kocher, Cryptography Research Division, Rambus, Inc., interjected to accept the blame for this vulnerability. “Leaving aside who is to blame,” Green replied, “the point here is that these things are incredibly difficult to get right. Even today, there are still vulnerabilities that probably we have not found.”

Green then described another TLS attack, known as Decrypting RSA with Obsolete and Weakened eNcryption (DROWN). DROWN takes advantage of the continued use of SSLv2 to lead a cross-protocol attack to decrypt TLS communications. “This is lousy, and it leads to . . . all sorts of bad things that we should not be seeing in protocols in 2016,” he said.

The Challenge of Complexity

A big problem, Green said, is that it is extremely challenging to prove today's protocols secure, or even to prove small parts of them secure, because they are so complex. As an example, Green pointed to a paper from 2012 that was the first to fully analyze *one* part of TLS, the Diffie-Hellman ephemeral protocol.² The next year, a paper analyzed the RSA handshake, another small aspect of TLS.³ In both analyses, the authors were unable to analyze the last renegotiation. Green concluded, "It turns out that our agility is actually our weakest point."

In 2014, researchers "gave up on proving the entire protocol secure and they decided to have computers do it," Green said. Yet this effort was inconclusive because, as Green put it, "nobody can actually understand what the computers did." However, the paper⁴ did provide some encouraging news: It showed that as long as the client and the server support only secure algorithms, TLS is a secure protocol. This is not actually what the TLS design community had been assuming, though; they had thought that as long as *the intersection* of the two sets of algorithms contained secure protocols, that was enough. However, he noted that this work showed that downgrade attacks can still find a way to use the insecure protocols, if they are also supported. "We need to improve TLS to deal with this kind of problem," Green concluded.

Practical Matters

Agility, then, is both good and bad, Green said. It allows us a way to move forward when attacks occur, but it also creates complexity in our protocols and enables new attacks. Whether we like agility or not is not the issue, Green stressed: "We are going to get agility no matter what we do because when we do not build agility into our protocols, other people do it for us, and they do it in really bad, dangerous ways." An example of this is the fact that most browsers support three TLS protocols as fallback maneuvers in case one fails, yet this agility creates insecure situations everywhere because of the possibility of downgrade attacks. "We have to design [agility] correctly because if we do not, we get the worst of all possible worlds," Green said.

Building on the argument—articulated many times throughout the workshop—that implementation is often the source of vulnerabilities, Bob Blakley, CitiGroup, Inc., posited that the situation is made even worse by the current convention that a reference

²T. Jager, F. Kohlar, S. Schäge, and J. Schwenk, 2012, On the Security of TLS-DHE in the Standard Model, pp. 273-293 in *Advances in Cryptology – CRYPTO 2012* (R. Safavi-Naini and R. Canetti, eds.), Lecture Notes in Computer Science, Vol 7417, Springer, Berlin, <https://eprint.iacr.org/2011/219.pdf>.

³H. Krawczyk, K.G. Paterson, and H. Wee, 2013, On the Security of the TLS Protocol: A Systematic Analysis, pp. 429-448 in *Advances in Cryptology – CRYPTO 2013* (R. Canetti and J.A. Garay, eds.), Security and Cryptology, Vol 8042, Springer, Berlin, <https://eprint.iacr.org/2013/339.pdf>.

⁴K. Bhargavan, C. Fournet, M. Kohlweiss, A. Pironti, P. Strub, and S. Zanella-Béguelin, 2014, Proving the TLS Handshake Secure (As It Is), pp. 235-255 in *Advances in Cryptology – CRYPTO 2014* (J.A. Garay and R. Gennaro, eds.), Security and Cryptology, Vol 8616, Springer, Berlin, <https://eprint.iacr.org/2014/182.pdf>.

implementation guide is released before the official specification guide is finalized. By virtue of being released first, Blakley asserted, this implementation guide will have errors that may be fixed in the final version, yet everyone will still refer to it simply because it is released first.

Tadayoshi Kohno, University of Washington, questioned whether anyone has tried to intentionally break backward compatibility mechanisms for a small set of users (on Google Chrome, perhaps) in order to study the results. Doing so, he suggested, might help to determine whether we need to support agility in certain circumstances or if it is acceptable to “move to something new” without stranding large numbers of users. In response, Green suggested that perhaps a more fruitful approach would be to tap into the developer community and the IETF, who have the clout to influence security decisions and build solutions.

Another participant mentioned the counterparts to agility (i.e., transition planning and execution), suggesting that any transition is going to break something and what matters is how one plans for that eventuality. Pointing to his closing slide, which featured a tweet about how much of the Internet is “rotted with age,” Green reiterated how difficult it is to eliminate code and security mechanisms that have become outdated. For example, he said during the disclosure of the Logjam vulnerability, Green’s team wanted to remove the 512-bit Diffie-Hellman from use and raise the minimum to 1,024 bits. Apple, Google, and others scanned the Internet and found that removing the 512-bit Diffie-Hellman would break 3 percent of the Internet, including many older Internet of Things devices that cannot be upgraded. That experience underscored Green’s conclusion that “we are stuck with these kinds of legacy devices that are dragging us back into the past.” Adam Langley noted that Google did remove the 512-bit Diffie-Hellman modules internally, though the decision had some negative repercussions for at least one Google team.

Recalling Richard George’s story about the multiple decades spent designing, testing, and implementing VINSON for radio communication, Steven Lipner, independent consultant, inquired about whether there is a way to achieve a similar but faster level of validation for security instruments being developed today—perhaps enabled by more people working in parallel. Green suggested the best way forward was for security-focused people to gain more traction in large companies and to fight for the resources to do it right. The current reliance on open source developers and research cryptographers to do this work has left us “in bad shape,” he said. Langley agreed that formal verification could create good systems and good software, and that the field of verification is improving. He pointed to the National Aeronautics and Space Administration and space shuttle software as an example. Green countered that instead of a slow but steady process, it is going to take a major breakthrough for a significant portion of cryptography to be formally verified.

EXTENSIBILITY AND AGILITY

Adam Langley, Google, Inc.

Adam Langley is a principal software engineer at Google, Inc. He discussed extensibility, which he defined as the ability to make additions to a protocol without requiring sweeping, simultaneous global updates (a model, he noted, that is generally impossible anyway). Extensibility is a necessary component of agility, Langley said, because it provides a practical approach to updating already-deployed systems. He also offered examples illustrating how extensibility plays out in real-world situations—for better or worse.

Extensibility in Transport Layer Security

Langley described examples of extensibility mechanisms in TLS. When two computers negotiate which version of the protocol to use, it is the extensibility mechanism that allows the computer with an updated protocol to communicate with a computer with the older protocol. It is a system Langley described as “commendably simple,” yet it does not always work. Sometimes the second computer does not recognize the updated information, preventing the communication from taking place.

When such failures occur, Langley said, “blame attaches to the last thing that changed.” If Google updates Chrome’s security mechanisms, for example, and suddenly triggers a bug in a bank’s website, users would blame the Chrome update for blocking access to their bank’s website, even though the update was meant to *increase* the users’ security. Google’s solution to such problems is to rely on an older “fallback” version while attempting to mitigate the disconnect. This intermediate step can last for a very long time; Langley said the browser community spent 15 years trying to fix several such bugs while relying on a fallback version to ensure continuity of service for users. Fallbacks are only used if the breaks caused by updated mechanisms will affect a substantial portion of traffic. If they only affect a small portion of users, say 0.1 percent of traffic, Langley said, “we just break things.” Although developers attempt to build in many extensibility and agility mechanisms, often these supposed points of flexibility wind up becoming “rusty solid with bugs,” Langley said.

Implications for Agility

From these experiences, Langley learned to “have one joint and keep it well oiled.” Repairs should focus on one specific area, such as compliance suites or implementations, and they should be well tested in order to predict performance and interoperability. Testing the extensibility mechanism on a virtually continual basis can help ensure whatever “joint” you are depending on “is going to bend when you need it to,” Langley said.

Experiences with extensibility underscore one of the workshop's broader themes, which is that agility should be approached "with hesitation, at least," Langley said, outlining the many costs of diverse options. Diversity, he said, generally results in more code and more bugs, thus reducing the ability for researchers and testers to focus deeply on any one of the many moving parts. As more interactions are possible, more bugs are created. He pointed to the process of defining primitives for use in TLS as an example of agility's secondary costs. More than 25 different symmetric cipher primitives have been defined so far; although only 9 are currently in use, each of the 25 were put through all the necessary IETF processes, a large expense of time and resources. Agreeing with Matthew Green's earlier statements, Langley asserted that many of today's challenges stem from decisions made in the 1990s, when technologists were distracted by the "crypto war" with the U.S. government: "An awful lot of these mistakes got baked in really deep, and we are still fighting them today," he said.

The International Context

Langley then turned to the international context, in particular the question of whether TLS should include ciphers for specific nations, which he termed "national pride cipher suites." Ciphers for Japan and South Korea, for example, were included in TLS. He views such cipher suites as "all cost and no benefit" and recommended that they be "fervently resisted." Though there might be nothing inherently wrong with them—and indeed, he conceded that to his knowledge, none, including those from Russia and China, contain anything deliberately malicious—he asserted that they offer no *technical* advantages over the National Institute of Standards and Technology–recommended Advanced Encryption Standard-Galois/Counter Mode (AES-GCM).

Returning to this issue in the discussion, Peter Swire, Georgia Institute of Technology, suggested that national cipher suites offer other advantages to nations, such as local expertise to better configure cryptography or local intelligence to better disable it. Agreeing that national security goals are likely part of the motivation for these cipher suites, Langley cautioned that the approach can backfire, arguing that making their own primitives, for example, would likely leave countries in a worse situation. Another drawback is that accommodating national cipher suites increases costs to everyone: While the nation in question may pay to create the cipher, the world bears the cost of supporting it. He then clarified that while he believes national ciphers should be resisted, it is unlikely to be feasible or necessary to "absolutely banish" them. Long-term Evolution (LTE) security uses a Chinese cipher, for example; however, Chrome does not support any national ciphers.

The Imperative to Retire Old Security Mechanisms

Building on previous workshop discussions around the issue of legacy cryptography, Langley described a stacked “conveyor belt” of security, with the newest and safest mechanisms at the top and the older, more vulnerable ones at the bottom (Figure 1 illustrates such a conveyor belt of symmetric cryptography primitives). “It is very important that we occasionally turn the crank on this conveyor belt so something falls off the bottom,” Langley asserted.

Retiring outdated security mechanisms is extremely difficult because it means that some devices, connections, or software products will no longer work. For example, it is easy to envision how removing one of the older security mechanisms could cause hundreds of thousands of televisions to stop working, something that many find unacceptable since users expect televisions to last a long time. However, Langley suggested that expecting a complex electronic product to have a lifespan of a decade or more is “increasingly nonviable.”

A significant downside of agility is that supporting outdated security can encourage its persistence, and new products may even be released today with cryptography from the *bottom* of the stack. People buying these products are unaware that they might have a very short lifespan because “they have jumped on this conveyor belt and we are about to turn the crank and they are about to fall off.” Making such decisions, Langley said, “is not a job you want if you wish to be well liked.” While large numbers of people will benefit from overall improved security, a concentrated group of users will pay the cost.

Symmetric primitive roadmap

AES-256-GCM / ChaCha20-Poly1305	Ok
AES-128-GCM	Ok for now
AES-CBC	Needs to die
3DES-CBC	Next to die
RC4	Nearly dead

FIGURE 1 “Conveyor belt” of symmetric cryptography primitives. SOURCE: Courtesy of Adam Langley, Google, Inc., presentation to the workshop.

During the discussion, Paul Kocher asked whether strategies for tying new features to new security—or making software with outdated security slower or otherwise less desirable—can help to motivate users to upgrade. Noting that Google has sometimes been able to offer “carrots” to users if they make updates, Langley said this approach can be helpful. However, it is not without problems: Hypertext Transfer Protocol Version 2 (HTTP/2), for example, was built to be usable only with modern cipher suites, but it ended up creating significant configuration problems. While he had good intentions, Langley said, “I am unsure whether that was a good idea.”

Noting that the focus of his presentation is on symmetric ciphers in TLS, Langley said that the same conveyor belt exists for asymmetric ciphers. In one sense, TLS is a bit simple because it is a negotiated protocol where two computers can communicate in order to reach a security agreement. In non-negotiated protocols, such as Public-Key Cryptography Standard #12 (PKCS#12), things are much harder because there is no conversation. PKCS#12, in practice, still uses Rivest Cipher 2 (RC2) (a 64-bit block cipher with known vulnerabilities) because that was how it was originally created. A similar situation exists in Secure/Multipurpose Internet Mail Extensions (S/MIME) (for encrypting email). If S/MIME is not communicating with a known channel, the recipient may not be able to decrypt the emails unless he agrees to use the *lowest* security mechanism they share in common.

Wrapping up, Langley pointed to the typically decade-long timelines of retiring security mechanisms such as Message-Digest Algorithm-5 (MD5), RSA 1024, and Secure Hash Algorithm-1 (SHA-1) in certificates. Preparations for these transitions are often years in the making, and use of the retired mechanisms often persists for years past their supposed final date.

Looking toward the future, with regard to the threat of quantum computing, Langley said only that he hopes he is retired before the threat becomes a reality. As a cynical upside, he posited that software itself has so many bugs that attackers might “not even bother” to attack the cryptography.

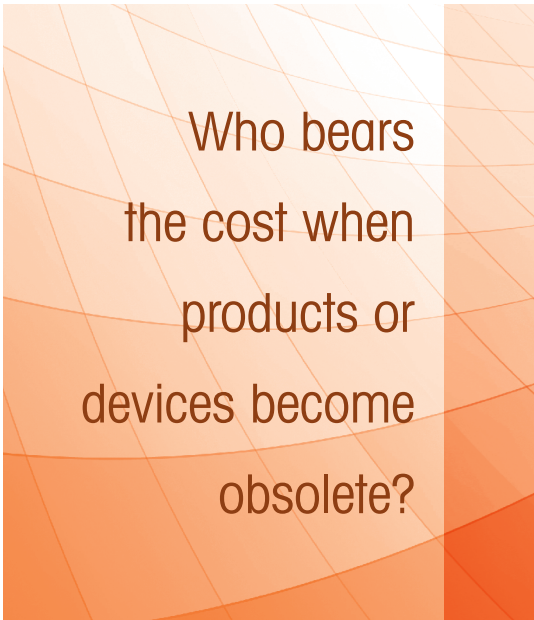
Who Bears the Costs?

Participants engaged in a lively discussion about the costs that are borne when products or devices become obsolete, and they explored how those costs might be allocated more fairly or equitably.

Prompted by a comment from Grosse, Langley described a situation in which Google disabled an older version of software used by televisions that caused a break for a tiny fraction of users—approximately 0.001 percent. After user complaints, Google relented and postponed the switch, giving the manufacturer a deadline to have the devices updated before the old version would be permanently disabled.

Deirdre Mulligan, University of California, Berkeley, noted that such experiences raise consumer protection questions—consider, for example, the implications of a break if the users who are most affected are also the least able to afford a replacement television. She pointed to the National Vaccine Injury Compensation Program as a model of one potential solution. Because vaccines are so widely beneficial for public health, the program provides compensation to anyone who is injured as a result of receiving a vaccine. Could a similar system be instituted to support the common good of cybersecurity, where subsidies could be given to those needing new devices who cannot afford to buy them?

Langley agreed that this is a challenge, describing the “painful realization” that often the users most likely to be affected by a break are the poorest in society, who are more



Who bears
the cost when
products or
devices become
obsolete?

likely to be using older devices and software. Expressing his view that subsidizing new device purchases could make removing legacy cryptology significantly easier, Langley conceded that he did not know how such a plan could work from a political standpoint. One partial solution Google supports is to allow manufacturers to test new products with Google’s test server to ensure that their devices work with the latest cryptography. The idea is that if a product does not work, the manufacturers will fix it, thus preventing new devices from being released with security that is at the “bottom of the conveyer belt.”

Delving more deeply into the question of who should bear the cost of replacing defunct products, participants noted the many players involved, including users, manufacturers, and service providers. Sara Brody,

Simply Secure, questioned how a system in which society at large bears the responsibility for upgrades would affect the incentive structures for manufacturers, who already reap profits from upgrades and new device purchases. Mulligan added that if a manufacturer decides to stop providing upgrades or services to a product, perhaps it should be required to release its code so that others could repair the flaws or install updates to keep those devices functioning. Building on this point, Brody noted that this problem is particularly acute for Internet of Things devices, especially when they are sold separately from the service that is required for them to connect online. If the company goes out of business, the service will be cut off and the device will be rendered useless. Grosse noted that one reason SSLv2 is widely supported overseas, especially in Asia, is because low-end “feature phones” use it to communicate with online banking sites. It is difficult to conceive of a system for replacing so many devices currently in use by a wide array of people that could continue to support the needed functionality but provide upgraded security, he said.

THE IMPORTANCE OF THE HUMAN FACTOR IN CRYPTOGRAPHIC AGILITY

Sara “Scout” Sinclair Brody, Simply Secure

Sara “Scout” Sinclair Brody is the executive director at Simply Secure, a nonprofit that aims to increase privacy and security through solutions that are human centered. Based on her background in the field of usable security, she posited that unless a system being built will use solely machine-to-machine communication, without contact with people at any point, human factors must be considered when designing the system’s security and agility mechanisms.

What role do humans play in cryptographic agility? Brody delineated two groups of users: the end users, who actually use the products, and the developers who create and apply the security and agility tools. In considering this second group of users, she urged attendees to include not only elite developers, such as those in attendance at the workshop, but also the vast majority of developers who are simply not experts in cryptography or agility. It is those developers, she noted, who are working on start-ups whose products may be insignificant now but could quickly balloon to include millions of users: “Ultimately, they are sort of the front line of cryptographic agility.” Beyond solving the very large problems being discussed at the workshop, Brody asserted the need to communicate effectively with this vast developer community about agility principles and policies.

Moving Toward a More Nuanced Conversation

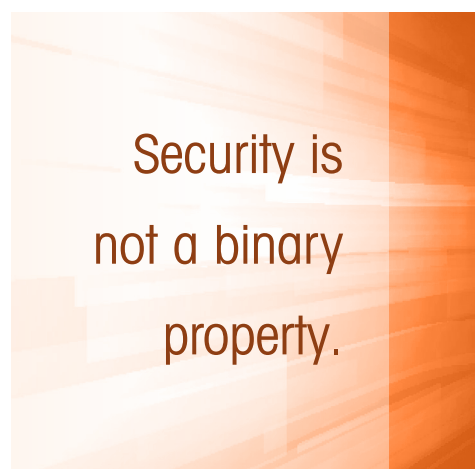
Security is a secondary task in the minds of most users and most developers, Brody said. Both users and developers are far more focused on the primary task of a given product, such as sending and receiving messages. Given this mindset and the limited resources most organizations devote to security, non-experts tend to think of security in a binary way: either a piece of software is secure, or it is not. They—and this includes both developers and end users—do not see the “nuances of gray” or think of security as a spectrum dependent on contexts or threat models.

Security experts sometimes reinforce this binary thinking, she said, by flatly rejecting or endorsing certain systems, or failing to recognize how design constraints or threat models contribute to a more nuanced landscape of options and decisions. Brody posited that a better approach is to “create more nuance in the conversation” around security needs by reinforcing that security is not a binary property. She also cautioned against letting “the perfect be the enemy of the good.”

Providing a Basis for Better Decisions

How can this be accomplished? Recognizing that many security decisions are situation dependent, Brody said that being able to see a stack ranking or prioritization list could help developers make better decisions about security. Another way to help developers would be if the cryptography community did something it is unaccustomed to doing: pass value judgment on the algorithms. “We tend to say, ‘You have to make that decision for yourself,’” she said. “No; we are the experts. Our community needs to be willing to say, ‘These algorithms are definitely better than these other algorithms.’” Brody pointed to Langley’s conveyor belt image as a way to guide a developer’s cryptography design choices and explain what cryptography under certain circumstances would require.

Another way to convey these messages is through the education process. Brody suggested students should be learning about—or perhaps be taught more effectively



about—not just system building, but also recognizing and planning for obsolescence, cryptographic agility, and system maintenance. In the discussion, Steven Lipner noted that in his experience, most developers do not know much about cryptography and are not taught about software vulnerability, even in the top engineering schools. On one hand, he said he recognized that not every developer can also be a security expert, because it would distract them from their primary task of building software, but on the other hand, developers do need a basic level of knowledge in order to best serve their end users. Brody pointed out that develop-

ers would also benefit from at least having access to people and resources to help with decision making. Lipner cautioned that “access to people” is not a scalable option, though improved access, in addition to a lot of information and the motivation to consume it, would be useful.

Recognizing Real-World Constraints

Developers are often concerned about how different governments are going to react to their use of cryptography, which Brody said was understandable given that developers are humans with real concerns and legitimate fears. “The legal aspects of cryptography are very scary to them,” she said. But while it may be easier to ignore the legal landscape of these issues, it is far more useful to engage in the debate on a deeper level and to truly understand both the technical and legal implications.

On the subject of legacy cryptography, she agreed with previous speakers that continuing to run insecure software, especially somewhere with sensitive data to protect, like a hospital, is a scary proposition. However, she noted that it is important to recognize

that sometimes users have no choice. A hospital using a magnetic resonance imaging machine running Windows XP, for example, cannot necessarily be expected to acquire a new machine in order to get the latest software.

Insight about developers, their constraints, and their motivations could help to surface better solutions, she said. An ethnographic study of developers, for example, could help reveal how they think about security, what their concerns are, and what barriers they face in implementing agility. In the discussion, Peter Swire suggested that the field of human-computer interaction is relevant in this context, though he had not previously considered applying human-computer interaction techniques to figure out how to get developers and others to adopt certain practices. Brody reiterated that however much technology there is in cryptography and agility, these are still, in the end, “human systems,” built and implemented by humans to serve human needs. These systems need agility, but what really makes agility happen is the developers, the standards bodies, and the research organizations—all of which are comprised of humans.

Systemic Improvements

Good defaults are important for developers and end users alike. Developers cannot create good user defaults when they are themselves offered too many security options without clear advice or explication of their differences. In such situations, developers often end up passing the decision on to the end user, who is, Brody noted, “not exactly the most qualified person to be deciding what cryptographics [they] should be using.” Providing good defaults first for developers, and then for users, would be far more helpful.

If good defaults cannot be offered, the next best thing is clear recommendations, she said. Even a simple drop-down menu with cryptography suites rated “recommended” and “not recommended” would be preferable to confusing acronyms that mean nothing to the non-expert. End users would appreciate seeing security options in binary terms and are in fact more likely to make good decisions this way.

Automatic updates that push important patches out to end users are also crucial, said Brody, though she recognized that they are “scary on some levels.” She suggested that the best practice is to push the update automatically and notify the user, although an easy opt-out mechanism should still be included with the alert.

The Benefits of Transparency

In closing, Brody stressed the value of transparency. End users, she said, should be able to determine which security library their various applications are running in order to evaluate the threat posed to them personally by a new vulnerability or attack. Such transparency would also be helpful to citizens in the context of national cipher suites and potential government surveillance.

Opening the discussion, Bob Blakley agreed that transparency is a good thing, but he said many end users do not have the education or background to make the best decisions when it comes to complex computer security issues. Brody agreed, clarifying that she would not expect average users to engage with this information regularly. Rather, she suggested having at least the *ability* to investigate one's computer security is helpful both for the general population and for populations whose security might be most at risk, such as journalists or human rights activists who might face threats of government surveillance. Those groups could benefit from increased security transparency because they have a particular need or interest in knowing the safety of their communications. If transparency becomes the standard, accountability could improve and software and applications would be updated regularly.

Research, Industry, and Policy Implications

The final two presentations of the workshop explored the reasons for pursuing cryptographic agility as well as some of the tricky research questions facing the field. Steven Bellovin focused on particular challenges in regard to creating agility in embedded devices, and John Manferdelli explored sources of resistance to agility, potential paths forward, and the threat of quantum computing. Both speakers touched briefly on the policy context.

AGILITY IS ESSENTIAL (BUT EXTREMELY CHALLENGING)

Steven Bellovin, Columbia University

Steven Bellovin, currently a professor of computer science at Columbia University, previously worked as a fellow at AT&T Labs and served as chief technologist for the U.S. Federal Trade Commission. He opened with the assertion that agility is essential: “It is not even worth discussing whether or not we need it,” he said. Declaring that little of the cryptography that was used 20 years ago is particularly useful anymore, he suggested the same may well be true 20 years hence. Public-key algorithms, for example, will not pass muster in a post-quantum world. Agility is necessary, he emphasized, because an algorithm cannot simply be turned off and replaced with a new one overnight.

Key Agility Challenges

Cryptography itself is already very difficult, and, like other workshop speakers, Bellovin acknowledged that adding agility invites complications such as new failure modes or downgrade attacks. The Transport Layer Security (TLS) anecdote illustrates this fact: many TLS errors stem from supporting legacy export ciphers needed for policies that were changed more than 15 years ago. “Most organizations cannot get this stuff right, even the very best,” Bellovin said. “It is just inherently a really hard problem.”

He pointed to the oldest cryptographic protocol in the open literature¹ as another example of these challenges; 18 years after the paper was published, a new attack on the protocol was discovered. Later, when newly discovered weaknesses in Message-Digest Algorithm-5 (MD5) and Secure Hash Algorithm-1 (SHA-1) required that new ones be deployed, Bellovin and Eric Rescorla reported that all the major Internet Engineering Task Force (IETF) protocols made mistakes with hash functions negotiation in part because only those two algorithms existed when the protocols were designed.² Put simply, the negotiation process required knowledge of the newer algorithms, but older systems would not know them. In this case even the IETF, representing the field’s elite experts, “tried hard and got it wrong,” he said, underscoring the risks for companies attempting to design their own cryptographic agility approaches.

Bellovin also expressed doubt that negotiation toolkits, code, or application programming interfaces (APIs) designed by standards bodies would necessarily fully address these challenges. Citing a study that found 80 percent of mobile applications contain cryptography errors in the TLS protocol alone,³ he asked, is it likely those designing new mobile applications would understand the even more complex systems under discussion today?

A further complication is that when code or protocols are designed successfully, they eventually are used by people all over the world, and so the possibility of transition from one cryptosuite to another must be factored into the design. Transition, he emphasized, is a very difficult event to anticipate. He suggested finding ways to test a protocol transition in a limited domain before the system is deployed broadly. This can help illuminate whether there are issues not only with the syntax of the transition but also with the semantics when there are multiple security systems involved. When signing executable programs, for example, the semantics of the signatures should signal whether or not the

¹R.M. Needham and M.D. Schroeder, 1978, Using encryption for authentication in large networks of computers, *Communications of the ACM* 21 (12): 993-999, <http://dl.acm.org/citation.cfm?id=359659>.

²S. Bellovin and E. Rescorla, 2006, “Deploying a new Hash Algorithm,” Paper presented at the NIST Cryptographic Hash Workshop, August 24-25, Santa Barbara, Calif., http://www.internetsociety.org/sites/default/files/deploying_new_hash_algorithm.pdf.

³Veracode, 2015, *State of Software Security Report: Focus on Application Development* (Supplement to Volume 6), <https://www.veracode.com/sites/default/files/Resources/Reports/state-of-software-security-focus-on-application-development.pdf>.

code is secure, he explained. He also noted that there have been a number of cases in which trouble stems from the version numbers of the protocols.

In the discussion, Bellovin shared his calculation that a comprehensive cryptographic upgrade takes about 12 to 15 years from algorithm design to deployment. That timeline accounts for the time it takes for older systems to die off and be replaced, which he estimated at about 5 years on average for general-purpose computers (shorter for items like phones and longer for items like cars), and about 10 years on average for the engineering, certification, protocol work, design, coding, and testing. Though this upgrade process takes a long time, Bellovin said, “I cannot see how to lower that number.”

Embedded Systems and the Internet of Things

Bellovin shared his perspective that the biggest problem in agility today is embedded systems such as the computers that are now being built into cars and many other Internet of Things devices. Many connected items in the Internet of Things world lack an update path. While the product itself may need to last for many years, the upgrade lifetime for such systems is actually quite short. Rather than supporting upgrades to existing chips and devices, vendors have a financial incentive to abandon old systems and focus on selling new ones with new chips. Today’s connected cars will likely be running cryptography

Should algorithm
and protocol update
capabilities be
decoupled from
more general
software updates?

that is 15-plus years old at the end of their useful lives, he noted, which raises a host of questions: How can security and functionality be balanced? Can the system even be updated? If it cannot, how could a new algorithm be added? Bellovin added, “It is especially serious when it comes to agility because algorithms age in a way that other software does not—because new attacks are discovered.”

Pointing to Dan Geer’s suggestion of a “suicide date” for embedded systems,⁴ Bellovin suggested that a guaranteed lifespan of 5 years—not shorter, not longer—might be one potentially viable approach. Such a system could be appealing to vendors, who would sell

consumers replacement products after 5 years, and potentially palatable for consumers, who typically are limited to short warranty periods and may benefit from a longer period of guaranteed support, even if it comes at the cost of a firm end date.

Bellovin considered potential approaches to making such devices updatable. Would it be possible, he wondered, to decouple the algorithm and protocol update capability

⁴D. Geer, 2014, “Security of Things Keynote Address,” address presented at Security of Things Forum, May 7, Cambridge, Mass., <http://geer.tinho.net/geer.secot.7v14.txt>.

from the more general software update in order to facilitate upgrades? Another problem emerges when vendors go out of business, a somewhat common occurrence in the high-tech world. An open API might allow users to make updates themselves in such situations, though an open API also invites its share of problems, not least of which is who maintains the public keys needed to authenticate such updates.

More promising, he suggested, are solutions that include parameterized algorithms that allow a higher iteration count, different round counts, and different substitution boxes, for example. Downgrade attacks and correctness errors could still cause problems, but these solutions could introduce more agility for embedded systems. New algorithms could be designed to allow for negotiable parameters, which might affect field lengths but would address the upgrade problem, he said.

Considering Unintended Consequences

Agility can allow for weaker cryptography to persist, which Bellovin emphasized was problematic for many reasons: “Backwards compatibility can be ‘bug-wards compatibility,’ and that is a threat we have to meet as well.” While downgrade attacks need to be prevented, he acknowledged that sometimes it is necessary to roll back to an older version of a security mechanism because the newer one is not working. Agility requires thinking seriously about consequences and making unpopular decisions. In addition, he said, out-of-band knowledge is important when transitioning to a new algorithm. For instance, it can help a service declare its security intentions, such as “I will never again accept TLS 1.1 or below. It is not secure. If you see this from me, it is wrong.” Yet such capability is not typically supported and is challenging in systems containing disparate embedded systems (for example, there are at least 50 in a modern car), which typically do not have a centralized system administrator.

New algorithms being written should be open to small changes without having to go through major overhauls to the algorithm, its field sizes, or iterations, Bellovin said. Designers need to prove not just the algorithm, but also iteration counts and key sizes that would work. In addition, negotiating a stronger mode of operation could help keep ciphers useful, as long as the data structures support that. Bellovin concluded, “We still need to protect the negotiation for algorithm agility.” Although this is challenging when even the primitives are under threat, Bellovin suggested research on privacy protection and secure “ratcheting” (always increasing the security levels) to protect against downgrade attacks could help address these challenges.

Peter Swire, Georgia Institute of Technology, asked whether there could be something to learn from the design of highly trusted critical systems, such as the software used in aviation. Bellovin responded that highly trusted systems in fact raise additional challenges in the context of agility because there is often not a full understanding of

the consequences of making changes. That is one reason, he said, that hospitals are not updating their Windows XP–dependent magnetic resonance imaging machines (and, he noted, putting their systems at risk as a result).

Wrapping up, Bellovin expanded on the privacy and human rights implications of certain approaches to cryptographic agility. One, he said, is that if agility weakens overall security, authoritarian governments will be able to spy on people more easily. Another concern is that too much flexibility for individuals to choose their cryptography could lead to “fingerprinting” users based on their preferred security profiles. Similarly, if a certain website requires an unusual combination of cryptographic parameters, this could make it easy to expose and track the activities of a specific user. A post-quantum algorithm cannot use today’s public-key algorithms because they would be broken too easily. The alternative, to use symmetric encryption with a universal key distribution center (KDC), would be a challenge, Bellovin said, because it creates a single vulnerable point that puts everyone’s privacy and security at risk if it were broken. A KDC could make it possible to track every website a user visits, creating, in Bellovin’s view, “a very serious privacy threat.”

AGILITY AND THE NEED TO PREPARE FOR FAILURE

John Manferdelli, Google, Inc.

John Manferdelli is a mathematician at Google, Inc. (as engineering director) and has also worked at Intel (as senior principal engineer) and Microsoft. He began by reiterating that agility is important—not only in the context of cryptography, but also more broadly—because nothing lasts forever. Key management systems and implementations eventually fail, and operational errors eventually arise. “You have to be able to change things quickly,” Manferdelli said, noting that at the same time, “You really cannot anticipate what you have to change.”

Aiming for Agility While Acknowledging Its Limitations

Manferdelli noted that agility is important and applies to more than just cryptographic agility—it is not always clear in advance what will need to be changed, and changed quickly. For example, implementation agility, or the ability to change things in the field, is crucial. Manferdelli pointed to a 2002 event in which a certification authority issued a certificate that looked like it belonged to Microsoft but was issued to another party. Agility allows a company to revoke fraudulent certificates. Instead, Microsoft had to reconfigure the operating system explicitly to render that certificate void.

Manferdelli expressed doubt that perfectly agile cryptography could ever be designed, in part because it is not possible to fully anticipate all user needs. While acknowledging that designers are “actually pretty good” at substituting cryptography algorithms like symmetric-key systems, as requirements become more complicated (e.g., wanting both secrecy and integrity), the challenges to designing cryptographic systems increase.

Commenting on an earlier statement from Butler Lampson, Manferdelli agreed with the advice to “always be a little circumspect about what you want to make secure.” There are some things we *can* get right, and we should try to do so—implementation agility is an important part of accomplishing this—but it must be acknowledged that no device or interface will work for “everything in the world forever and ever,” he said. This idea comes into play in the debate over cipher negotiation, for example. On the one hand, negotiation can be a bad thing because there is a chance that a developer or user could make a mistake. On the other hand, developers and users need tools. Trying to create a solution that completely satisfies all scenarios creates an argument with no right answer, and no winner, Manferdelli said.

Another reason we need agility, he emphasized, is because anything that is used long enough will eventually be cracked by attackers. “Really, the best line of defense is being able to change things,” he said, suggesting that modest goals are preferable to trying to create something to last 50 years. Even algorithms change, he said, noting that this has not always, in his experience, been well appreciated: When he first began working on security for Windows, for example, there was no one working on cryptography because it was considered so unlikely that anyone would ever need to move on from MD5, Data Encryption Standard (DES), or RSA 1024.

Facing the Quantum Threat

Quantum computing is seen as perhaps the biggest reason public-key algorithms might need to change. Quantum computing would also bring new opportunities, he noted. Computers have been built on the same model since the 1940s, and quantum computing would offer strikingly different capabilities. For that reason alone, it would be wise to plan for agility and to take advantage of cryptographic advances where they emerge. Whatever the likelihood that quantum computing will be invented, and however uncertain we are about when it might become a reality, Manferdelli emphasized that it is important to plan for a quantum threat because of its potential catastrophic consequences. On the positive side, he is optimistic that quantum-resistant algorithms will be created and that they can be added to existing cryptographic systems. While recognizing that dealing with quantum computing would be a huge change (key sizes alone would need to be much larger), Manferdelli expressed confidence that the computing world can meet these challenges.

During the discussion, William Sanders, University of Illinois, Urbana-Champaign, explored the topic of implementation agility, questioning whether it would be straightforward to create a framework now that would be usable if quantum computing capabilities were to be realized. Manferdelli responded that while he does believe agility is important and improving, it is essential to recognize that errors will inevitably occur. “You are just not going to get it right the first time,” he said. Testing and understanding the agile layer fully, before implementation, will save money and configuration problems in the long run. He suggested creating and testing quantum-resistant algorithms now, perhaps inside a cipher suite. Either an upgrade strategy or short service life could help when a new protocol inevitably goes wrong.

Why Resist Agility?

Manferdelli considered the reasons for resistance to the idea of using or requiring agility. Besides the quantum threat, there are plenty of good reasons to use agility today—for example, to address the mistakes that are causing today’s keys and information to leak. Having fully agile systems is ideal, but even “just changing keys every once in a while would not be such a bad idea,” he said.

In the past, he said, one reason for not using agility was that the code was so brittle and easily broken when changes were attempted. Another was that there was a pervasive resistance to adding new software. Manferdelli said both of these issues are now more nuanced, the code libraries have improved, and algorithms can now be switched out successfully as long as the format of the output is not changed too much.

Managing keys is another reason people avoid agility. Noting a rumor that Apple had not allowed any new certificates for 6 months, he explained that root keys and certificates last a long time, which causes problems. He pointed to some improvements in this area, including key pinning (a security technique used to prevent “man-in-the-middle” attacks) and certificate transparency. Key pinning via upgrades allows a secure, trusted key to persist through the upgrade. Such a system allows a measured, reliable security device to travel with a user.

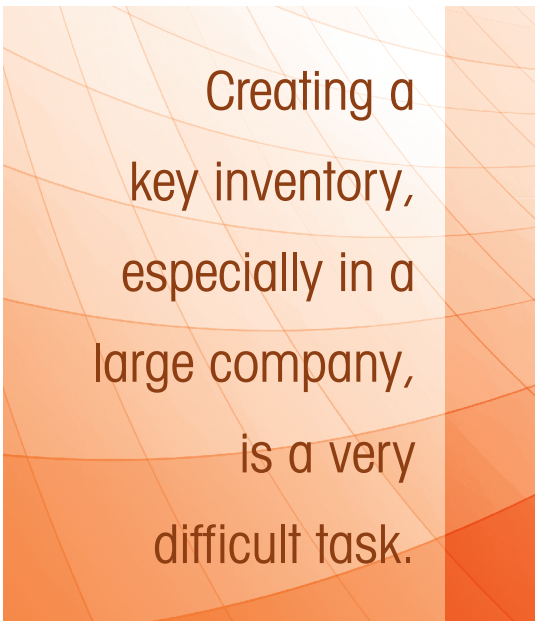
Another factor is that some businesses might not want to remove old algorithms because they do not want to reduce their market share, which is not something that technological improvements can necessarily address. Often, businesses do not make changes *until* a catastrophic event happens; otherwise, they do not see their business as being impacted.

Preparing for Failure

The biggest problem when making upgrades is that, as with cryptography generally, one can never predict what is going to break, and Manferdelli asserted that the debate over

agility today will not be solved until upgrades can be guaranteed to happen. Noting that the old Bell telephone system was required to run expensive tests to check periodically for catastrophic failure, he suggested it might be good for computer systems and the people who build them to run similar tests.

Whether one views the glass as half-full or half-empty (or completely empty), it is crucial to prepare for failure, Manferdelli asserted. For example, key management might be configured so that keys are expected to change frequently. “Any prudent person will



Creating a
key inventory,
especially in a
large company,
is a very
difficult task.

really want to be able to make sure they can change their keys quickly,” he said. While recognizing that complex systems have a lot of moving parts, he asserted that it is possible to allow for key agility, not just algorithm agility. Embedded applications with certificate transparency, which make issuing fraudulent certificates more difficult, could also help.

It is also necessary, Manferdelli noted, to continue monitoring and analyzing keys to make sure that the retired ones are truly retired. Kocher, Cryptography Research Division, Rambus, Inc., expanded on this point in the discussion. One step in deciding whether to retire a protocol is to determine how many people or programs are still using it. Kocher wondered if that inadvertently allows attackers to encourage the use of an older,

unsafe protocol: if they can force enough traffic through it, it might never be turned off. Clarifying that he had spoken specifically about key use, and not protocols, Manferdelli also expressed support for monitoring and analyzing protocol use, as well as creating an inventory of existing protocols. Returning to the focus on keys, he asserted that “there is really no downside in keeping an eye on what keys people are using and going after them and tapping them on the shoulder and saying, ‘This was not a great idea.’” To this, Bob Blakley, CitiGroup, Inc., added that creating a key inventory, especially in a large company, is a very difficult task.

Wrapping up his presentation, Manferdelli shared his hope that a sensible conclusion could be reached on the topic of access to plaintext by law enforcement. Under certain circumstances, he allowed that there should be a way for law enforcement to access evidence in data, but giving law enforcement universal access is not, in his view, the optimal way to achieve it.

The Broader Problem of Software Updates

Participants discussed the broader context of agility. Thinking holistically, the agility problem is not merely one of cryptography; it is a problem for the entire computing system. Steven Bellovin categorized software update problems as “fiendishly difficult” research problems that are much harder than the cryptographic agility problem on its own. He pointed out that every major software vendor has experienced update problems, where a patch either had to be recalled or replaced, or it ended up breaking devices completely. Manferdelli concurred, though he noted signs of progress, including a recent switch in parts of the U.S. government from a policy of not updating software until exhaustive qualification and certification tests are complete to embracing updates as they are released.

Fred Schneider, Cornell University, asked how governance of software updates might fit into the discussion, describing a situation in which a user buys a product that is later updated in a way that affects the product’s security or privacy framework. Who has control over access to our devices, he asked—the manufacturers, the government, or some sort of mixed authority? Agreeing that it presents a complicated research problem, Manferdelli said that the usual practice is to set expectations and legal responses, though the expectations in this context are currently unclear. With regard to the matter of setting a lifetime for embedded devices, for example, Manferdelli said that he did not have a specific answer. “I would certainly like it if there were well-formed, well-thought-out expectations,” he concluded. “Then, you could think about how policy might flow from that.”

Discussion and Wrap-up

The workshop concluded with a period of open discussion, giving speakers and participants a chance to emphasize what they considered the most essential issues and revisit concerns raised earlier in the day. This chapter, organized into thematic areas, describes the content of the final discussion, highlighting some of the broader themes that emerged throughout the workshop.

Opening the discussion, Paul Kocher, Cryptography Research Division, Rambus, Inc., said that the day's presentations had "turned what I thought was a hard problem into a *really* hard problem." Agility is necessary, but imperfect, he summarized. What can we do to advance agility in a way that does not cause as many problems as it solves?

PLANNING FOR AN UNCERTAIN FUTURE

Although we can never predict exactly what the future will hold, two main themes emerged throughout the workshop: (1) the potential threat of quantum computing and (2) the near certainty that vulnerabilities will eventually be discovered in any security system, even without quantum computing.

Kocher expanded on the difficulties of devising strategies to address as-yet-unknown problems. Some challenges, such as specific ciphers failing, are easier to solve, while others, such as quantum computing, inevitable software bugs, or the need to

change root keys managed by someone else, are much more difficult. The “unknown unknowns” present particular challenges: What could happen? What is the probability that it will happen?

Sara Brody, Simply Secure, noted that because we know certain types of vulnerabilities will inevitably keep happening, a network to share information and resources when a bug or other problems are noticed would be useful. Bob Blakley, CitiGroup, Inc., pointed out that some sectors, such as financial services, have created Information Sharing and Analysis Centers to do just that.

Participants explored the implications of a catastrophic security failure—such as one caused by quantum computing—and what might be done now to prevent or prepare for such an event. Peter Swire, Georgia Institute of Technology, suggested that institutions will be critical to forging a path forward during and after such an event, and he posited that addressing a disaster will require not only technical solutions and expertise but also communication with society at large and the identification of critical leaders across sectors.

Blakley brought up a common practice in the corporate security world: using tabletop or paper exercises to test out new ideas or predict their consequences. Perhaps this approach could be applied to help organizations envision the problems they may face by simulating a scenario of cryptographic systems breaking. Anita Allen, University of Pennsylvania, agreed that tabletop exercises would be useful in designing for transition and, even more importantly, in designing for disaster. In the context of disaster, she added that it is also important to plan responses to breaches or damages that threaten cultural heritage. Butler Lampson, Microsoft Corporation, suggested that live exercises, though more expensive than tabletop exercises, can be more illustrative. Several participants noted that organizations often do both tabletop and live exercises, learning different lessons from each.

TECHNICAL SOLUTIONS

Participants explored ideas for technical approaches that could help to mitigate agility challenges and allow for more effective ways to improve the prospects of future agility.

Kocher raised the fundamental tension created by the fact that, because we do not know what future protocols and implementations will look like, we cannot build or test them now. Compounding this is the extremely fast pace at which companies develop and deploy products today, leaving little time for thorough testing. Identifying testing as an area with room for improvement, he suggested that perhaps, as part of ensuring compliance with standards, designers could use standard test suites or put more emphasis on checking to make sure that implementations interoperate with other systems.

Later, Swire suggested that all of the interactions within today's dense networks create issues that cannot be identified with tests that focus on updating one system interacting at one level. Given that it is so difficult to test an individual system (and get results that are reflective of the real-world context), he asked if a new approach is warranted.

Kocher pointed out that there are good test suites available for ciphers but not for protocols. Our current disaster-planning mechanisms are reliant on these protocols, he said, but there is no easy way to test them to see if they will work when they are needed. And while they are not actually hard to test, there is no incentive for companies to do so. Perhaps one solution could be to build a shared protocol testing center that would benefit the entire ecosystem of electronic communications—systems, products, and users. John Manferdelli, Google, Inc., suggested the notion of a “safe harbor” in which the demonstration of some specific level of upgradeability and transparency would be considered due diligence. If crafted well, such an approach could help to put bounds on the expectations for testing and upgrades that would be useful for designers and manufacturers.

Migration—moving existing systems from one cryptography system or approach to another—is an additional key issue. Kocher identified four separate elements to migration: designing better cryptography, implementing cryptography for maximum interoperability, turning off old cryptography, and fully removing the old cryptography. Each of these elements presents unique challenges.

Blakley used a medical metaphor to introduce what he called a radical proposal: while liver transplants are possible because the liver is a discrete organ, spinal transplants are not because the spine is so interconnected with the rest of the body. He wondered if cryptography could be made more like a discreet organ by constraining in ways that would allow engineers to separate cryptographic agility from systems updates. Kocher pointed out that hardware would also need to be addressed. Manferdelli noted that as a designer, he was sympathetic to the goal of streamlining systems, but he expressed concern about the potential for this approach to sacrifice aspects of the cryptography itself and perhaps undermine security.

SHARING EXPERTISE

Participants noted that agility requires making tough choices, and those with the greatest expertise should be helping others make informed decisions. “When the experts cannot decide among themselves so you pass the difficult problem off to a non-expert, that is not really fixing the problem,” Kocher asserted. Transparency and governance are also areas in which experts should be making or more actively informing choices, he said.

Steven Bellovin, Columbia University, noted that all stakeholders, including researchers, standards bodies, engineers, and developers, have a role in solving agility problems, but their specific roles depend on which problem is being examined. Software updates are a vendor-specific problem, he suggested. Systems administration could benefit from more academic research, but thousands of details and consequences, as opposed to unifying principles, make this area “messy” and therefore not very popular among academic researchers. Standards bodies, he suggested, also need to increase their involvement. Pointing to examples in which things have gone wrong despite the involvement of standards bodies like the Internet Engineering Task Force, Bellovin asserted that standards bodies and academia need to feel a greater sense of responsibility or ownership for standards and upgrades. “Academia has to look at this even when it is not nice and neat and academic, and this does not happen,” he said.

With regard to a problem mentioned by nearly every speaker at the workshop—obsolescence and legacy cryptography—David Vladeck, Georgetown University, proposed looking for legal solutions, pointing to warranties as a potential analog from which to draw.

INTERNATIONAL ISSUES AND HUMAN RIGHTS

Participants noted that cryptography and agility are in fact global issues, and different nations have drastically different philosophies on privacy, security, and government access to data and communications. Swire noted the prospect of increased regulation by countries including China and Russia, though he expressed doubts that the United States would move very far in that direction because doing so would threaten its own technology industry. The more general point—that there will likely be significant variation among nations in approaches to cryptography and technology more broadly—is something he noted will increase the complexity of cryptographic agility approaches.

Several participants expressed concern about the impact of cryptographic agility on human rights. Deirdre Mulligan, University of California, Berkeley, said that some governments will restrict the use of encryption by citizens. Mulligan and Allen expanded on that point, explaining that encryption and anonymity are enablers of other human rights, including freedom of expression, freedom of speech, and limited government surveillance. Mulligan pointed out that David Kaye, the United Nations’ Special Rapporteur on the Promotion and Protection of the Right to Freedom of Opinion and Expression, recently concluded that restrictions on cryptography as an enabler of freedom of expression must be consistent with human rights laws, provided for by law, only imposed for legitimate reasons, and compliant with strict standards. He concluded that any proposal to restrict encryption should be subject to public comment, follow legislative processes,

and be subject to strong procedural and judicial safeguards; these same concerns for human rights should apply, Mulligan suggested, in the context of decisions made not only by governments, but also by companies like Google, Facebook, and Microsoft. “I think that there is a real need to be really sensitive to the role of agility and thinking about human rights,” Mulligan asserted. “I think it is a really important part of the conversation.” Building on this point, Allen suggested that rather than anonymity or encryption being discussed as human rights themselves, it is perhaps more useful to focus on the role of encryption and anonymity in other human rights including freedom of expression, freedom of speech, and limited government surveillance.

Tadayoshi Kohno, University of Washington, added that user demographics should also be a part of the human rights discussion. All users should benefit equally from agility and upgrade mechanisms, not just those who can afford to buy (and rapidly replace) high-end devices.

AGILITY BEYOND CRYPTOGRAPHY

Noting that failures are inevitable, Steven Lipner, independent consultant, underscored that everyone would stand to benefit from agility mechanisms to deal with vulnerabilities, whether they come from quantum computing, algorithm errors, or merely from the passage of time. One step forward, he suggested, is funding research into these areas. Another is for large organizations to devote more engineering expertise to prevent and prepare for failure.

William Sanders, University of Illinois, Urbana-Champaign, pointed out that the workshop discussions had touched on many aspects of agility—keys, algorithm replacement, full software upgrades, and more—and suggested that this wide-ranging field may benefit from a closer look at what, exactly, is desirable in agility. The answers to such questions could help inform an agility framework and determine a goal for “how agile” our systems should be.

Lampson suggested that an important aspect of the agility context has been overlooked: computing is increasingly service based. While updates to hardware or software matter, so do cloud-based services such as Microsoft’s Office 365 or Google’s Chrome. He expressed concern that many of the agility ideas being explored are “rooted in computing practices that are rapidly disappearing.” Building on this point, Mulligan noted that the Internet of Things, products without update channels, and other such issues also raise important questions that go beyond cryptographic agility itself. She referred back to Brody’s suggestion that examining the behaviors and motivations of developers and users could provide useful tools for addressing these broader issues.

Appendixes



Workshop Agenda and Participants List

WORKSHOP ON CRYPTOGRAPHIC AGILITY AND INTEROPERABILITY SPRING 2016 MEETING OF THE FORUM ON CYBER RESILIENCE

May 9, 2016

Keck Center of the National Academies of Sciences, Engineering, and Medicine
Washington, D.C.

AGENDA

- | | |
|------------|---|
| 10:00 a.m. | Welcome and Overview
Fred B. Schneider, Forum on Cyber Resilience Chair |
| 10:05 | Context Setting
Bob Blakley, Forum Member
Paul Kocher, Forum Member |
| 10:55 | Break |
| 11:10 | Government and Infrastructure
Session Moderator: Steven Lipner, Forum Member
Kerry McKay, National Institute of Standards and Technology
Richard George, Johns Hopkins University Applied Physics Laboratory |
| 12:00 p.m. | Break for lunch |
| 1:00 | Standards and Security Implications
Session Moderator: Mary Ellen Zurko, Forum Member
Russ Housley, Vigil Security, LLC
David McGrew, Cisco Systems, Inc. |
| 1:50 | Break |

2:05	Engineering at Scale and User Implications Session Moderator: Eric Grosse, Forum Member Matthew Green, Johns Hopkins University Adam Langley, Google, Inc. Sara Brody, Simply Secure
3:20	Break
3:35	Research, Industry, and Policy Implications Session Moderator: Bob Blakley, Forum Member Steven Bellovin, Columbia University John Manferdelli, Google, Inc.
4:25	Wrap-up Discussion and Q&A Moderator: Paul Kocher, Forum Member
5:00	Reception Forum members, speakers, and attendees

PARTICIPANTS LIST

Anita Allen, University of Pennsylvania
Steven Bellovin, Columbia University
Bob Blakley, CitiGroup, Inc.
Shenae Bradley, National Academies of Sciences, Engineering, and Medicine
Sara (Scout) Sinclair Brody, Simply Secure
Fred Cate, Indiana University
David Clark, Massachusetts Institute of Technology
Donna Dodson, National Institute of Standards and Technology
Jon Eisenberg, National Academies of Sciences, Engineering, and Medicine
Richard George, Johns Hopkins University
Matthew Green, Johns Hopkins University
Eric Grosse, Google, Inc.
David Hoffman, Intel
Russ Housley, Vigil Security, LLC
Paul Kocher, Cryptography Research Division, Rambus, Inc.
Tadayoshi Kohno, University of Washington
Butler Lampson, Microsoft Corporation
Adam Langley, Google, Inc.
Steven Lipner, Independent Consultant
John Manferdelli, Google, Inc.
Brad Martin, National Security Agency
David McGrew, Cisco Systems, Inc.
Kerry McKay, National Institute of Standards and Technology
Lynette Millett, National Academies of Sciences, Engineering, and Medicine
Deirdre Mulligan, University of California, Berkeley
Katiria Ortiz, National Academies of Sciences, Engineering, and Medicine
Tony Sager, Council on Cybersecurity
William Sanders, University of Illinois, Urbana-Champaign
Fred B. Schneider, Cornell University
Peter Swire, Georgia Institute of Technology
David Vladeck, Georgetown University
Mary Ellen Zurko, Cisco Systems, Inc.

B

Planning Committee Biographies

FRED B. SCHNEIDER, *Chair*, is the Samuel B. Eckert Professor of Computer Science at Cornell University and chair of the department. He joined Cornell's faculty in Fall 1978, having completed a Ph.D. at Stony Brook University and a B.S. in engineering at Cornell in 1975. Schneider's research has always concerned various aspects of trustworthy systems—systems that will perform as expected, despite failures and attacks. Most recently, his interests have focused on system security. His work characterizing what policies can be enforced with various classes of defenses is widely cited, and it is seen as advancing the nascent science base for security. He is also engaged in research concerning legal and economic measures for improving system trustworthiness. Dr. Schneider was elected a fellow of the American Association for the Advancement of Science (AAAS; 1992), the Association of Computing Machinery (ACM; 1995), and the Institute of Electrical and Electronics Engineers (IEEE; 2008). He was named a professor-at-large at the University of Tromsø (Norway) in 1996 and was awarded a doctor of science (*honoris causa*) by the University of Newcastle-upon-Tyne in 2003 for his work in computer dependability and security. He received the 2012 IEEE Emanuel R. Piore Award for contributions to trustworthy computing through novel approaches to security, fault tolerance, and formal methods for concurrent and distributed systems. The National Academy of Engineering (NAE) elected Schneider to membership in 2011, and the Norges Tekniske Vitenskapsakademi (Norwegian Academy of Technological Sciences) named him a foreign member in 2010. He is currently a member of the National Academies of Sciences, Engineering, and Medicine's Naval Studies Board and Computer Science and Telecommunications Board, and he is founding chair of the National Academies' Forum on Cyber Resilience.

ANITA L. ALLEN is the Henry R. Silverman Professor of Law and Professor of Philosophy at the University of Pennsylvania Law School, where she is also the university's vice provost for faculty. She is an expert on privacy law, bioethics, and contemporary values, and is recognized for her scholarship about legal philosophy, women's rights, and race relations. In 2010 Allen was appointed by President Obama to the Presidential Commission for the Study of Bioethical Issues. Her books include *Unpopular Privacy: What Must We Hide* (2011); *Privacy Law and Society* (2011); *The New Ethics: A Guided Tour of the 21st Century Moral Landscape* (2004); *Why Privacy Isn't Everything: Feminist Reflections on Personal Accountability* (2003); and *Uneasy Access: Privacy for Women in a Free Society* (1988).

She co-edited (with Milton Regan) *Debating Democracy's Discontent* (1998). Allen, who has written more than 100 scholarly articles, has also contributed to popular magazines and blogs and frequently appeared on nationally broadcast television and radio programs. Allen has served on numerous editorial and advisory boards, and on the boards of a number of local and national nonprofits and professional associations including the Hastings Center, the Electronic Information Privacy Center, and the Bazelon Center for Mental Health Law.

ERIC GROSSE is a senior member of the Google security team and was previously vice president of security and privacy engineering at Google in Mountain View, California, leading a team of 512 who ensure systems and data stay safe and users' privacy remains secure. Improved and wider use of Secure Sockets Layer (SSL), stronger consumer authentication technology, detection and blocking of espionage, transparency on legal requests for data, sophisticated malware analysis, and tools and frameworks for safer building of web applications are among the achievements of the Google security team. Before Google, Grosse was a research director and fellow at Lucent Bell Labs where he worked on security, networking, algorithms for approximation and visualization, software distribution, and scientific computing. He has a Ph.D. in computer science from Stanford University.

BUTLER W. LAMPSON is a technical fellow at Microsoft Corporation and an adjunct professor at the Massachusetts Institute of Technology. He has worked on computer architecture, local area networks, raster printers, page description languages, operating systems, remote procedure call, programming languages and their semantics, programming in the large, fault-tolerant computing, transaction processing, computer security, "what you see is what you get" (WYSIWYG) editors, and tablet computers. He was one of the designers of the Scientific Data Systems (SDS) 940 time-sharing system, the Alto personal distributed computing system, the Xerox 9700 laser printer, two-phase commit protocols, the Autonet local area network, the Simple Public-Key Infrastructure system for network security, the Microsoft Tablet personal computer software, the Microsoft Palladium high-assurance stack, and several programming languages. He received the ACM Software Systems Award in 1984 for his work on the Alto, the IEEE Computer Pioneer award in 1996 and von Neumann Medal in 2001, the Turing Award in 1992, and the NAE's Draper Prize in 2004. He is a member of the National Academy of Sciences and the NAE as well as a fellow of the ACM and the American Academy of Arts and Sciences.

SUSAN LANDAU is professor of cybersecurity policy in the Department of Social Science and Policy Studies at Worcester Polytechnic Institute. Landau has been a senior staff privacy analyst at Google, a distinguished engineer at Sun Microsystems, and a faculty member at the University of Massachusetts, Amherst, and Wesleyan University. She has held visiting positions at Harvard University, Cornell University, Yale University, and the Mathematical Sciences Research Institute. Landau is the author of *Surveillance or Security? The Risks Posed by New Wiretapping Technologies* (2011) and co-author, with Whitfield Diffie, of *Privacy on the Line: The Politics of Wiretapping and Encryption* (1998, rev. ed. 2007). She has written numerous computer science and public policy papers and op-eds on cybersecurity and encryption policy and testified in Congress on the security risks of wiretapping and on cybersecurity activities at National Institute of Standards and Technology's Information Technology Laboratory. Landau currently serves on the Computer Science Telecommunications Board of the National Academies. A 2012 Guggenheim fellow, Landau was a 2010-2011 fellow at the Radcliffe Institute for Advanced Study, the recipient of the 2008 Women of Vision Social Impact Award, and also a fellow of the American Association for the Advancement of Science and the ACM. She received her B.A. from Princeton University, her M.S. from Cornell University, and her Ph.D. from MIT.



Speaker Biographies

STEVEN BELLOVIN is a professor of computer science at Columbia University, where he does research on networks, security, and especially why the two do not get along. He joined the faculty in 2005 after many years at Bell Labs and AT&T Labs Research, where he was an AT&T Fellow. While a graduate student, Bellovin helped create Netnews; for this, he and the other perpetrators were given the 1995 Usenix Lifetime Achievement Award (The Flame). He is a member of the National Academy of Engineering (NAE) and is serving on the Department of Homeland Security's Science and Technology Advisory Committee; he has also received the 2007 National Institute of Standards and Technology (NIST)/National Security Agency (NSA) National Computer Systems Security Award. Bellovin is the co-author of *Firewalls and Internet Security: Repelling the Wily Hacker* and holds a number patents on cryptographic and network protocols. He has served on many National Academies of Sciences, Engineering, and Medicine study committees, including those on information systems trustworthiness, the privacy implications of authentication technologies, and cybersecurity research needs; he was also a member of the information technology subcommittee of a National Academies study group on science versus terrorism. He was a member of the Internet Architecture Board (IAB) from 1996 to 2002; he was co-director of the Security Area of the Internet Engineering Task Force (IETF) from 2002 through 2004. He received a B.A. from Columbia University, and an M.S. and Ph.D. in computer science from the University of North Carolina, Chapel Hill.

BOB BLAKLEY is global director of information security innovation at CitiGroup, Inc. He recently served as plenary chair of the National Strategy for Trusted Identities in Cyberspace Identity Ecosystem Steering Group and as research and development co-chair of the Financial Services Sector Coordinating Council for Critical Infrastructure Protection and Homeland Security. He is currently a member of the Forum on Cyber Resilience—a National Academies' Roundtable. Prior to joining CitiGroup, Inc., Blakley was distinguished analyst and agenda manager for identity and privacy at Gartner and Burton group. Before that, he was chief scientist for security and privacy at IBM. He is past general chair of the Institute of Electrical and Electronics Engineers (IEEE) Security and Privacy Symposium and the Applied Computer Security Associates New Security Paradigms workshop. He was awarded the Annual Computer Security Applications Conference's Distinguished Security Practitioner award in 2002 and is a frequent speaker at information security and computer industry events. Blakley was general editor of the Ob-

ject Management Group CORBASecurity specification and the OASIS Security Assertion Markup Language specification, and is the author of *CORBASecurity: An Introduction to Safe Computing with Objects*. He was the first chair of the Open AuTHentication Joint Coordinating Committee. He also participated in the National Academies' panels "Authentication Technologies and Their Privacy Implications" and "Whither Biometrics." Blakley holds 20 patents in cryptography and information security, and he publishes regularly in the academic literature on information security and privacy. Blakley received the A.B. in classics from Princeton University, and the M.S. and Ph.D. in computer and communications science from the University of Michigan.

SARA "SCOUT" SINCLAIR BRODY is executive director of Simply Secure. Simply Secure functions as part consultancy, part research group, as it advises those using secure communication tools on how to make those tools easier to use. Brody has been establishing and managing the organization and works with user experience experts, software developers, and users in order to improve the usability of open-sourced secure-communications software. Previously, as an assistant product manager and later a product manager at Google, she worked on projects such as two-step verification, the Android operating system, and uProxy. She currently holds two patents in connection with her research. She earned her B.A. in computer science and French from Wellesley College and her Ph.D. in computer science from Dartmouth College.

RICHARD M. (DICKIE) GEORGE is the senior advisor for cybersecurity at the Johns Hopkins University (JHU) Applied Physics Lab (APL). At APL, he works on a number of projects sponsored by the U.S. government and provides oversight on additional efforts. Prior to joining APL, he worked at NSA as a mathematician from 1970 until his retirement in 2011. While at NSA, he wrote more than 125 peer-reviewed technical papers on cryptomathematical subjects, ranging from new mathematical methods for attacking cryptographic algorithms, to security evaluations of complex systems. While at NSA, his work was recognized by the Cryptomath Institute as the most important mathematical contribution to the Agency's mission in 1980, as well as by two Presidential Rank awards, a Superior Technical Award, and a Distinguished Senior Technical Achievement Award. He was elected to distinguished member status into both the Cryptanalytic Society (Kryptos) and the Cryptomath Society (CMI). He served as the technical director of the Information Assurance Directorate for 8 years until his retirement.

MATTHEW GREEN is assistant professor at the JHU Information Security Institute. He researches techniques for privacy-enhanced information storage, anonymous payment systems, and bilinear map-based cryptography. He had worked previously as assistant

research professor and assistant research scientist at JHU before becoming an assistant professor. Prior to working for JHU, he was a former partner in Independent Security Evaluators, a custom security evaluation and design consultancy. He worked as a senior technical staff member at AT&T Labs/Research. Green runs the blog “A Few Thoughts on Cryptographic Engineering.” He earned his B.S. in computer science from Oberlin College, a B.M. in electronic music from Oberlin College, and his M.S. and Ph.D. in computer science from JHU.

RUSS HOUSLEY formed Vigil Security, LLC, in September 2002 with the goal of helping customers design and implement diligently watchful security solutions. Housley has worked in the computer and network security field since 1982. Before starting Vigil Security LLC, he worked at the Air Force Data Services Center, Xerox Special Information Systems, SPYRUS, and RSA Laboratories. His security research and standards interests include security protocols, certificate management, cryptographic key distribution, and high assurance design and development practices. He has been active in many security standards organizations; his recent focus has been on the IETF. Since March 2013, Housley began serving in the position of IAB chair, which is a voting member of the IAB, as well as a non-voting ex-officio member of the Internet Engineering Steering Group (IESG), a voting member of the IETF Administrative Oversight Committee (IAOC), and a trustee for the IETF Trust. This position gives Housley a voice in the main leadership and management groups within the IETF. From March 2007 to March 2013, he served in the position of IETF chair, making him the chair of the IESG, a voting member of the IAB, a voting member of the IAOC, and a trustee for the IETF Trust. From March 2003 to March 2007, Housley served in the position of IETF security area director, making him a member of the IESG. Prior to accepting the area director position, he chaired the IETF Secure/Multipurpose Internet Mail Extensions Working Group, and he has contributed to several cornerstone Internet public-key infrastructure standards (including RFC 5280). In November 2004, Housley was recognized by the IEEE 802.11 working group for his contributions to IEEE 802.11i-2004, which fixes the severe security shortcoming of the Wired Equivalent Privacy. Russ provided major contributions to several security protocols, including the Cryptographic Message Syntax, SDNS Security Protocol 4 (SP4), SDNS Message Security Protocol, IEEE 802.10b Secure Data Exchange Protocol, and IEEE 802.10c Key Management Protocol. Housley received his B.S. in computer science from Virginia Tech in 1982, and he received his M.S. in computer science from George Mason University in 1992.

PAUL KOCHER is president and chief scientist of Cryptography Research, a division of Rambus, Inc. Kocher has gained an international reputation for his research and innovative designs in cryptography. An active contributor to major conferences and leading security initiatives, he has designed numerous cryptographic applications and protocols which are successfully deployed in real-world systems. His accomplishments include discovering timing attacks and differential power analysis (including techniques for preventing against these vulnerabilities), helping author the widely used Secure Sockets Layer 3.0 standard, and leading the design of the record-breaking Data Encryption Standard Key Search machine. Kocher has recently focused on developing anti-piracy technologies for securing digital content. He was elected to the NAE in 2009. Kocher founded Cryptography Research, previously held positions at RSA Security, and was a founding member of Valicert, Inc. (now Tumbleweed). He holds a B.S. degree from Stanford University.

ADAM LANGLEY is a principal software engineer at Google, Inc., where he manages SSL/TLS across Google's products.

JOHN MANFERDELLI is engineering director at Google, Inc. He currently serves as a member of the Information Science and Technology advisory group at the Defense Advanced Research Projects Agency and the Defense Science Board. Prior to joining Google, Manferdelli was a senior principal engineer at Intel Corporation and co-PI (with David Wagner) for the Intel Science and Technology Center for Secure Computing at the University of California, Berkeley. Before that, he was a distinguished engineer at Microsoft and was an affiliate faculty member in the computer science department at the University of Washington. During his time at the University of Washington, he was responsible for research regarding computer security, cryptography, systems, and quantum computing. He holds a B.S. in physics from Cooper Union for the Advancement of Science and Art and a Ph.D. in mathematics from the University of California, Berkeley.

DAVID MCGREW is a Cisco fellow at Cisco Systems, Inc. He is in the Advanced Security Research Group at Cisco, where he works to improve security through applied research, standards, and product engineering. He has been with Cisco Systems, Inc., since 1998. He began his career at Cisco as a manager of software development engineering, where he managed the Crypto and Virtual Private Network Software Development team in the Internet Technologies Division and later formed and managed the Strategic Cryptographic Group within the Office of Chief Technology Officer. As a technical leader in foundational engineering, he developed Secure Real-time Transport Protocol (RTP) standard and reference implementation. He returned to Software Development Engineering as manager II and reformed and managed the Advanced Cryptographic Development Group, and con-

tinued to manage the group as technical leader II before becoming a Cisco fellow. Prior to his career at Cisco, McGrew was a cryptographic scientist at Trusted Information Systems, Inc. He has been instrumental in the development of several cryptographic algorithms and protocols, including industry standards such as the Galois/Counter Mode of operation for efficient and scalable authenticated encryption, and Secure RTP for encrypted voice and video. He is currently listed on 42 patents, has previously served as chair of the Internet Research Task Force (IRTF) Crypto Forum Research Group for years, and was active in the IETF. He earned his B.S. in physics from Ohio State University and his Ph.D. in theoretical nuclear physics from Michigan State University.

KERRY MCKAY is a computer scientist in the cryptographic technology group at NIST, where she develops cryptographic standards and performs research. Her projects include topics in Transport Layer Security, random bit generation, lightweight cryptography, and Secure Hash Algorithm-3.

FRED B. SCHNEIDER is the Samuel B. Eckert Professor of Computer Science at Cornell University and chair of the department. He joined Cornell's faculty in Fall 1978, having completed a Ph.D. at Stony Brook University and a B.S. in engineering at Cornell in 1975. Schneider's research has always concerned various aspects of trustworthy systems—systems that will perform as expected, despite failures and attacks. Most recently, his interests have focused on system security. His work characterizing what policies can be enforced with various classes of defenses is widely cited, and it is seen as advancing the nascent science base for security. He is also engaged in research concerning legal and economic measures for improving system trustworthiness. Schneider was elected a fellow of the American Association for the Advancement of Science (1992), the Association of Computing Machinery (1995), and the IEEE (2008). He was named a professor-at-large at the University of Tromsø (Norway) in 1996 and was awarded a doctor of science (honoris causa) by the University of Newcastle-upon-Tyne in 2003 for his work in computer dependability and security. He received the 2012 IEEE Emanuel R. Piore Award for contributions to trustworthy computing through novel approaches to security, fault tolerance, and formal methods for concurrent and distributed systems. The NAE elected Schneider to membership in 2011, and the Norges Tekniske Vitenskapsakademi (Norwegian Academy of Technological Sciences) named him a foreign member in 2010. He is currently a member of the Naval Studies Board and the Computer Science and Telecommunications Board of the National Academies, and he is founding chair of the Forum on Cyber Resilience.

OTHER RECENT REPORTS OF THE COMPUTER SCIENCE AND TELECOMMUNICATIONS BOARD

A 21st Century Cyber-Physical Systems Education (2016)
Continuing Innovation in Information Technology: Workshop Report (2016)
Data Breach Aftermath and Recovery for Individuals and Institutions: Proceedings of a Workshop (2016)
Exploring Encryption and Potential Mechanisms for Authorized Government Access to Plaintext:
Proceedings of a Workshop (2016)
Future Directions for NSF Advanced Computing Infrastructure to Support U.S. Science and Engineering in
2017-2020 (2016)
Privacy Research and Best Practices: Summary of a Workshop for the Intelligence Community (2016)

Bulk Collection of Signals Intelligence: Technical Options (2015)
Cybersecurity Dilemmas: Technology, Policy, and Incentives: Summary of Discussions at the 2014
Raymond and Beverly Sackler U.S.-U.K. Scientific Forum (2015)
Interim Report on 21st Century Cyber-Physical Systems Education (2015)
A Review of the Next Generation Air Transportation System: Implications and Importance of System
Architecture (2015)
Telecommunications Research and Engineering at the Communications Technology Laboratory of the
Department of Commerce: Meeting the Nation's Telecommunications Needs (2015)
Telecommunications Research and Engineering at the Institute for Telecommunication Sciences of the
Department of Commerce: Meeting the Nation's Telecommunications Needs (2015)

At the Nexus of Cybersecurity and Public Policy: Some Basic Concepts and Issues (2014)
Emerging and Readily Available Technologies and National Security: A Framework for Addressing Ethical,
Legal, and Societal Issues (2014)
Future Directions for NSF Advanced Computing Infrastructure to Support U.S. Science and Engineering in
2017-2020: An Interim Report (2014)

Geotargeted Alerts and Warnings: Report of a Workshop on Current Knowledge and Research Gaps (2013)
Professionalizing the Nation's Cybersecurity Workforce? Criteria for Future Decision-Making (2013)
Public Response to Alerts and Warnings Using Social Media: Summary of a Workshop on Current
Knowledge and Research Gaps (2013)

Continuing Innovation in Information Technology (2012)
Computing Research for Sustainability (2012)
The Safety Challenge and Promise of Automotive Electronics: Insights from Unintended Acceleration
(2012, with the Board on Energy and Environmental Systems and the Transportation Research Board)

The Future of Computing Performance: Game Over or Next Level? (2011)
Public Response to Alerts and Warnings on Mobile Devices: Summary of a Workshop on Current
Knowledge and Research Gaps (2011)
Report of a Workshop on the Pedagogical Aspects of Computational Thinking (2011)
Strategies and Priorities for Information Technology at the Centers for Medicare and Medicaid Services (2011)
Wireless Technology Prospects and Policy Options (2011)

Limited copies of CSTB reports are available free of charge from:
Computer Science and Telecommunications Board
Keck Center of the National Academies of Sciences, Engineering, and Medicine
500 Fifth Street, NW, Washington, DC 20001
(202) 334-2605/cstb@nas.edu
www.cstb.org